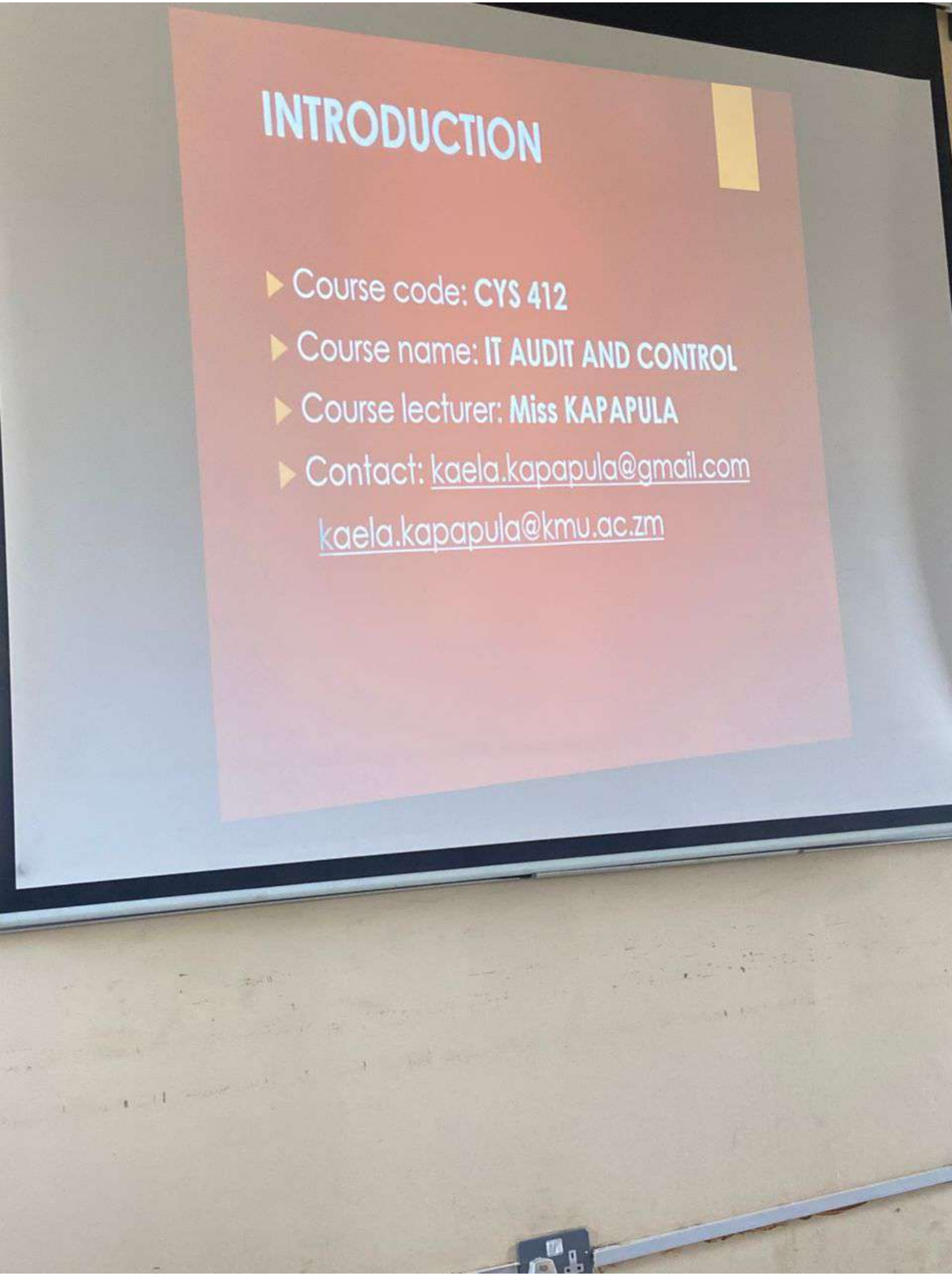
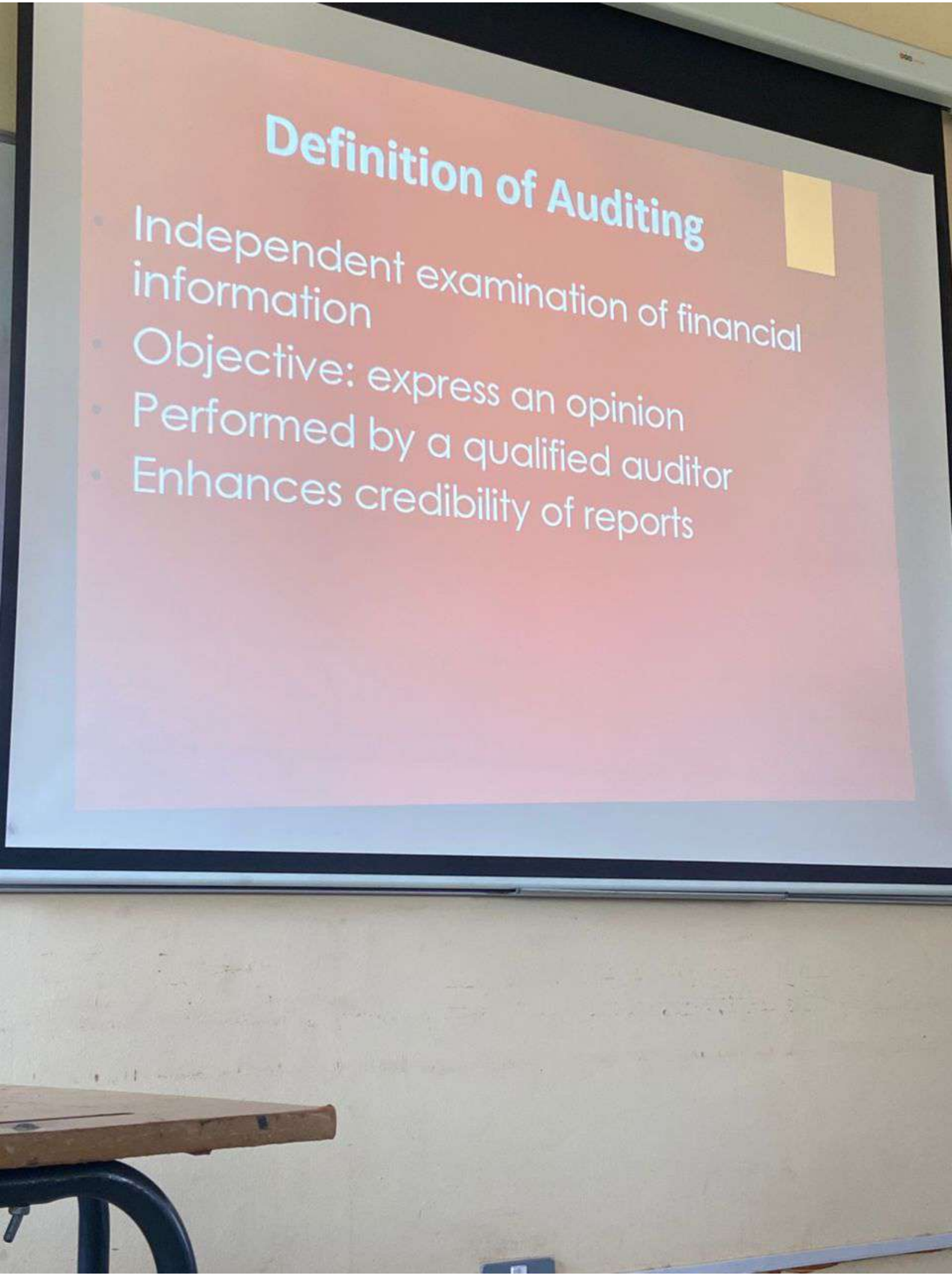
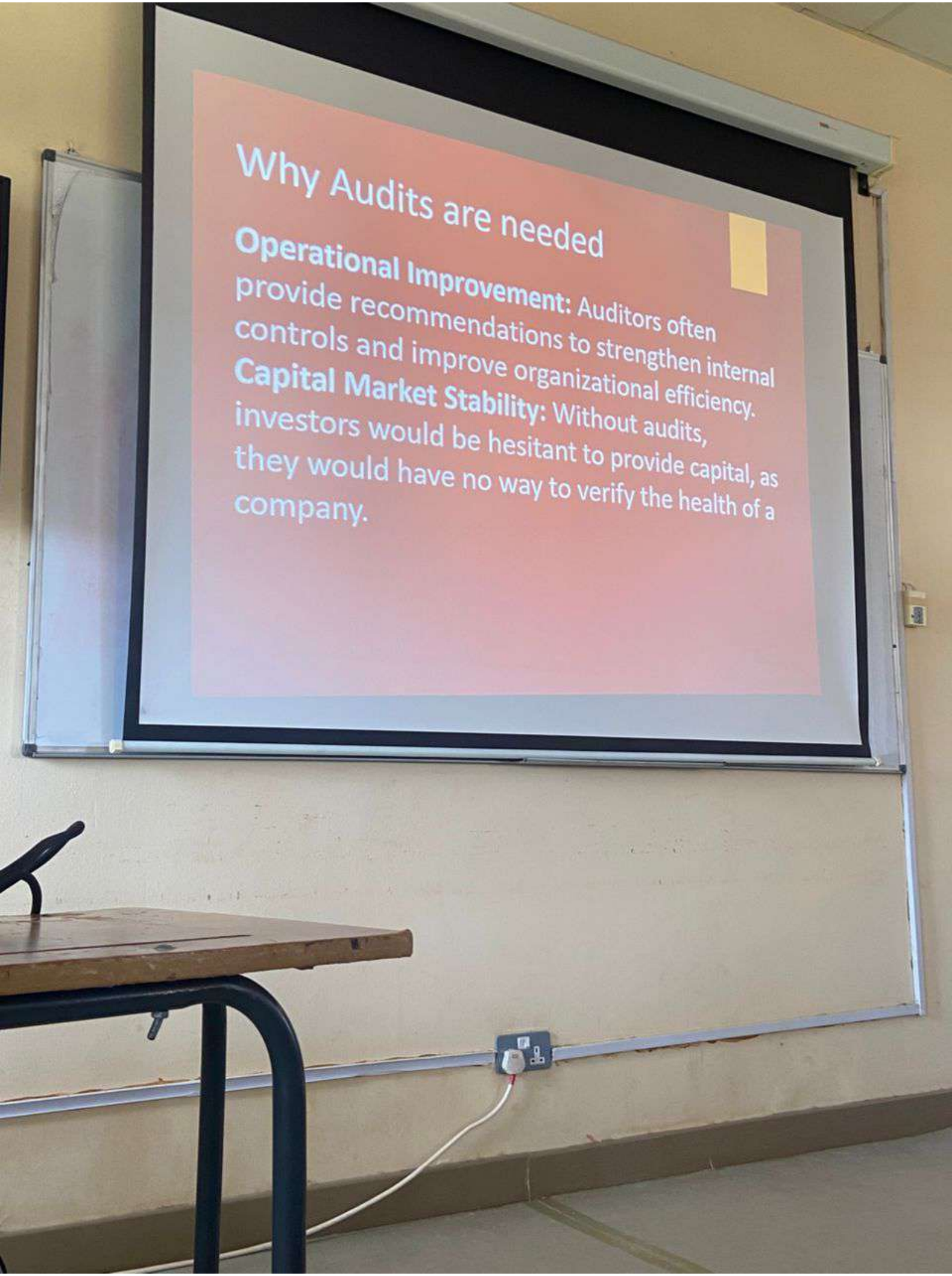
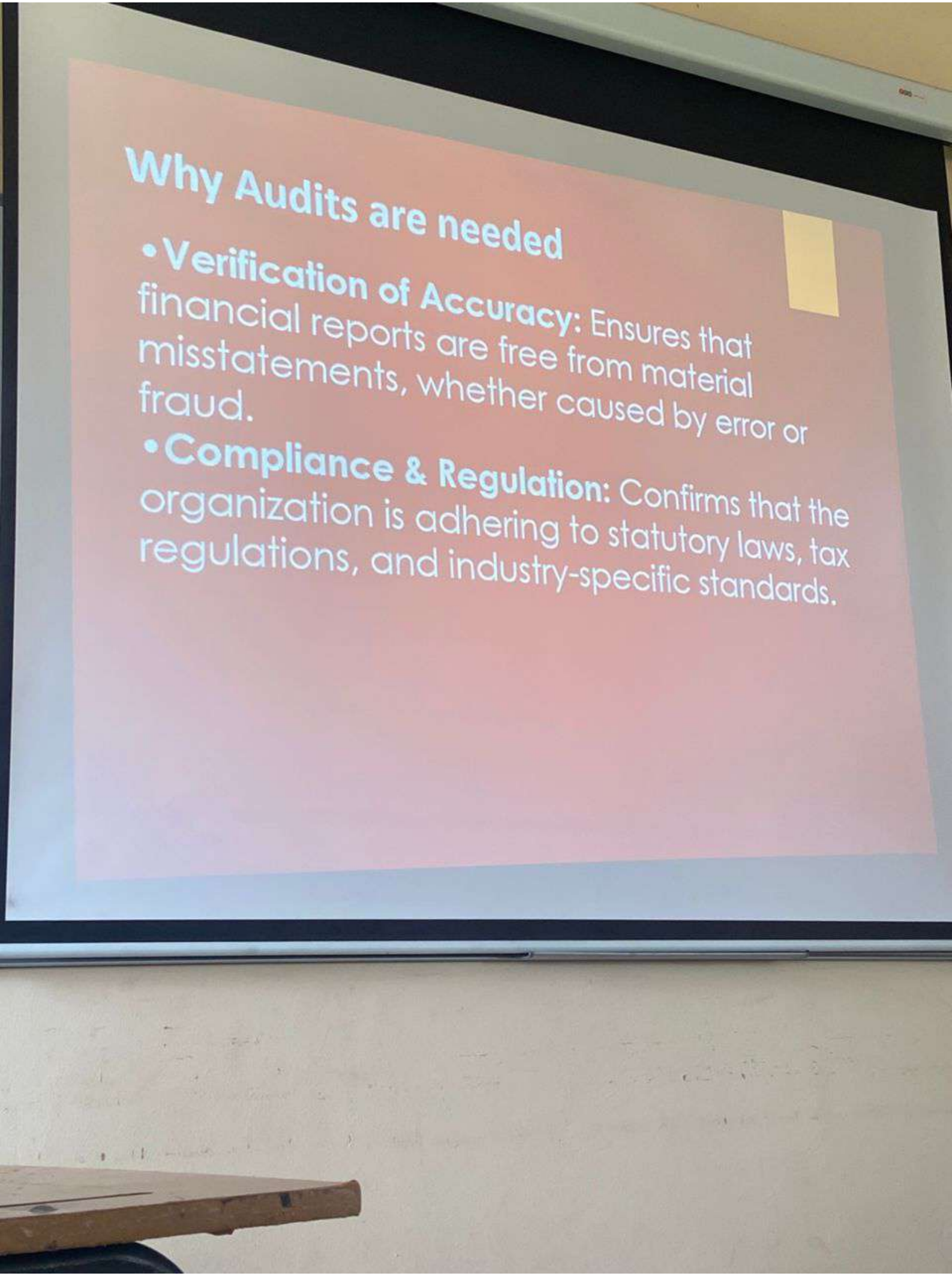
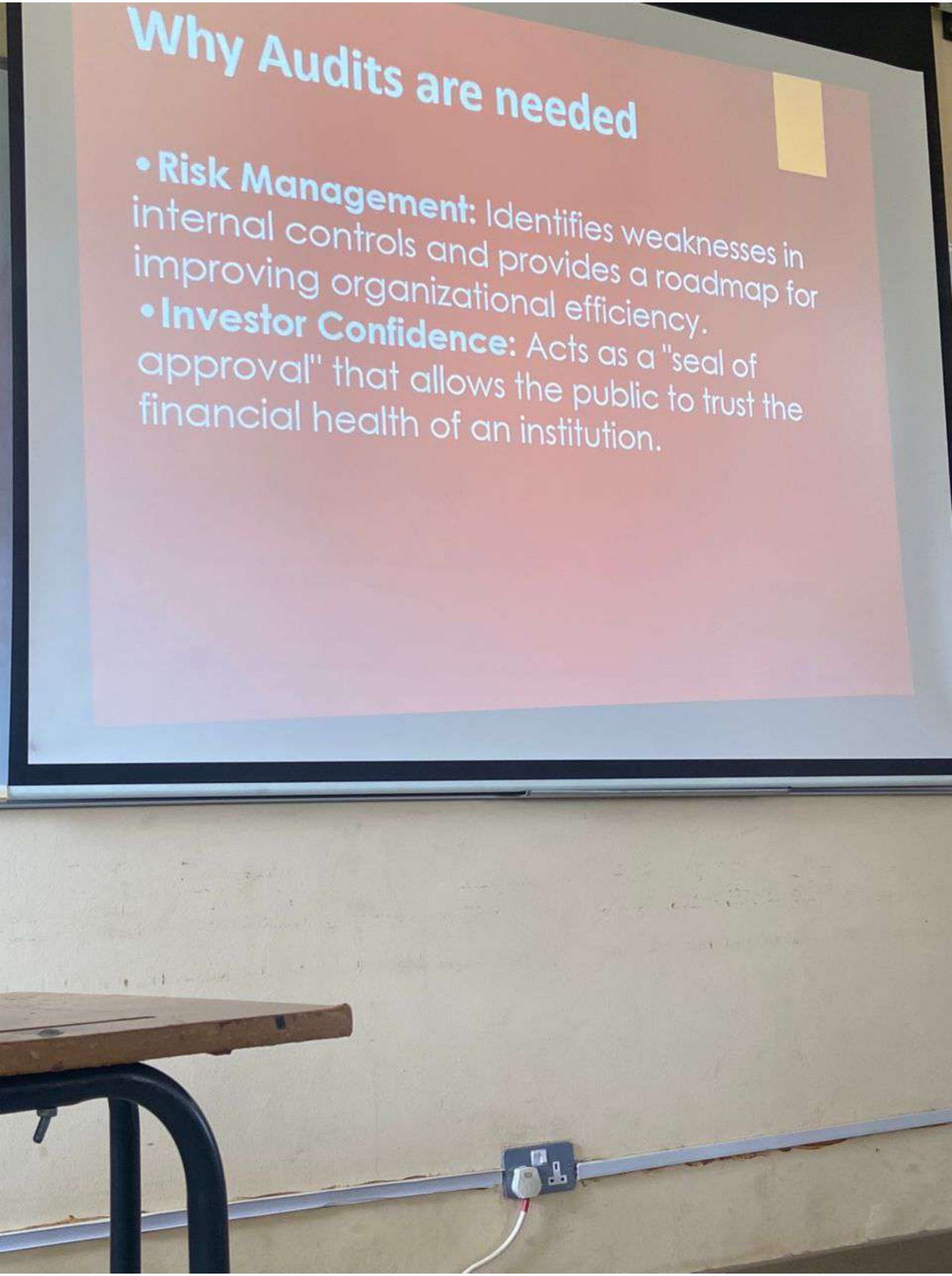

INTRODUCTION
Course code: CYS 412
Course name: IT AUDIT AND CONTROL
Course lecturer: Miss KAPAPULA
Contact: kaela.kapapula@gmail.com
kaela.kapapula@kmu.ac.zm

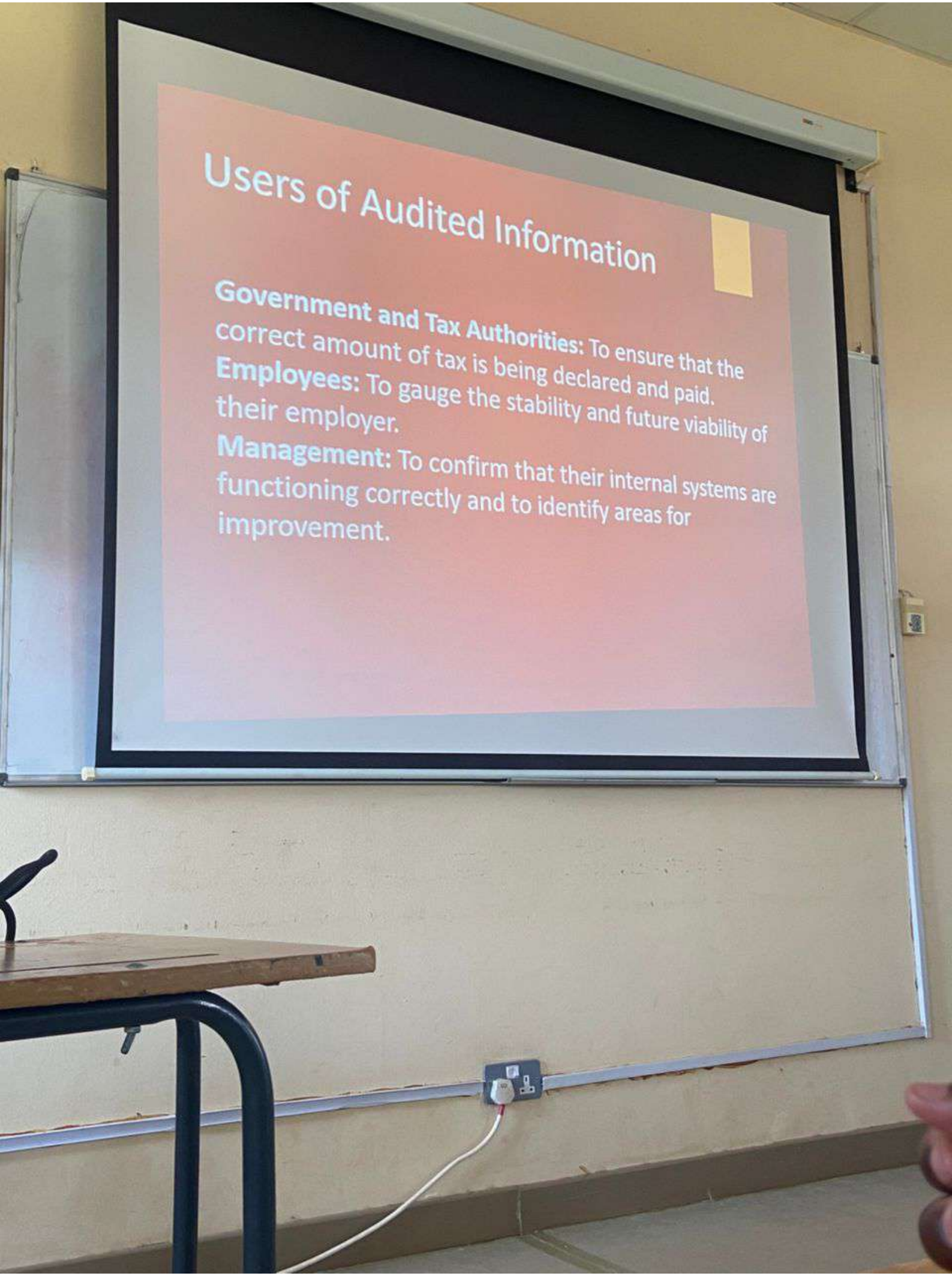

Definition of Auditing
Independent examination of financial information
Objective: express an opinion
Performed by a qualified auditor
Enhances credibility of reports

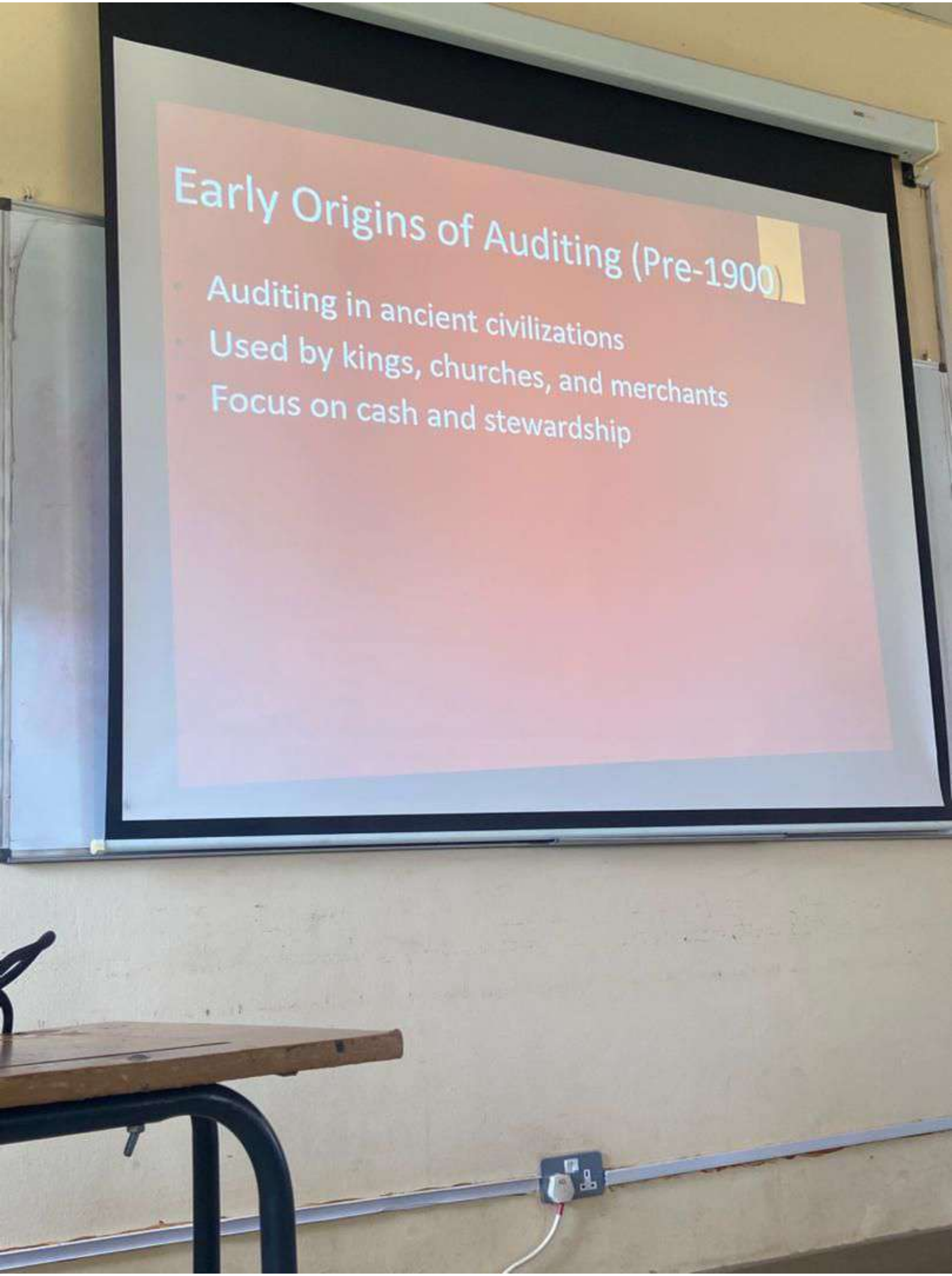

Why Audits are needed
Audits serve several critical functions in a modern economy:
Error and Fraud Detection: They help identify mathematical mistakes, technical errors, or deliberate misappropriation of funds.
Compliance: They ensure that an organization is following statutory laws, industry regulations, and internal policies.

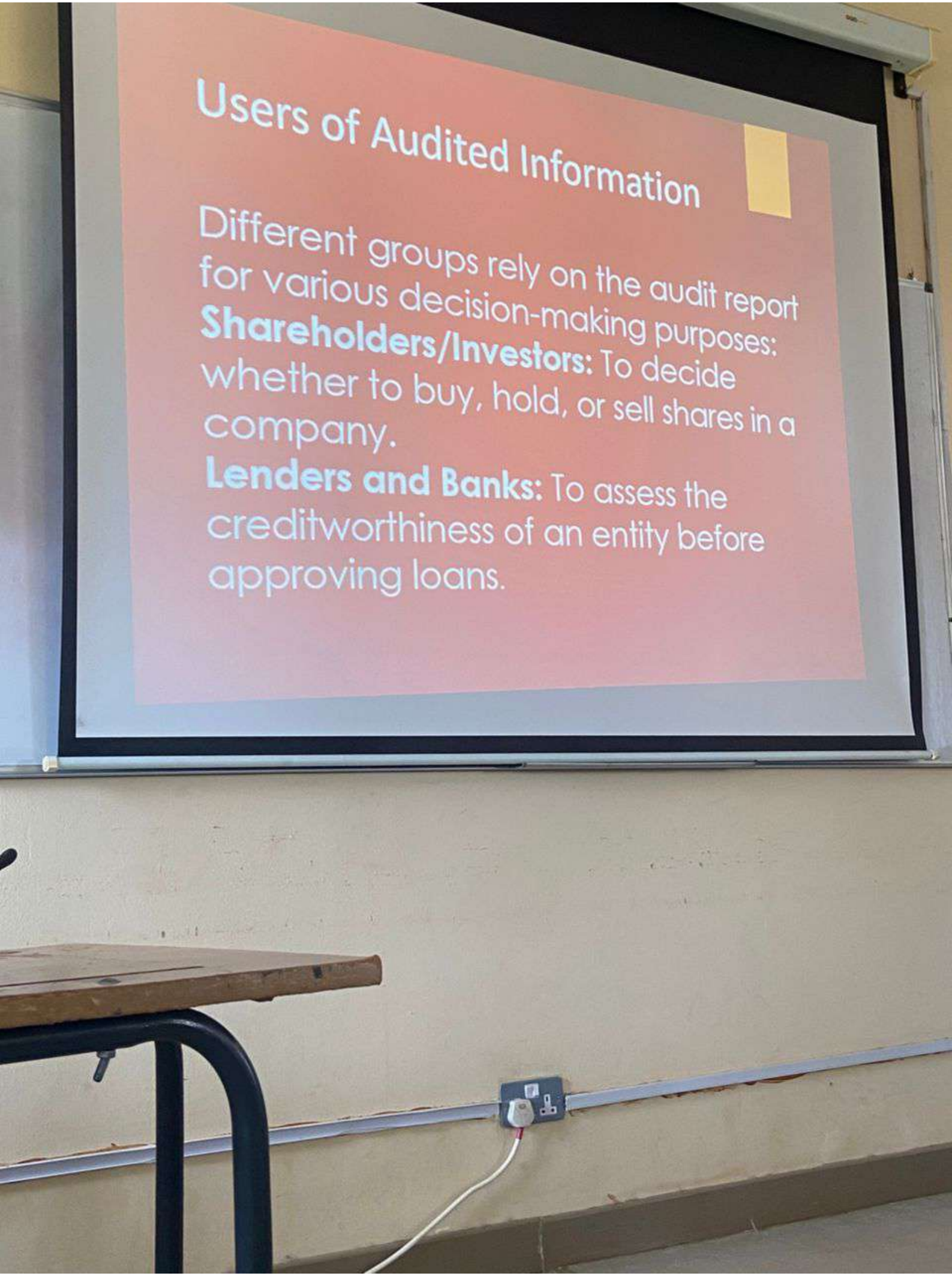

Why Audits are needed
Operational Improvement: Auditors often provide recommendations to strengthen internal controls and improve organizational efficiency.
Capital Market Stability: Without audits, investors would be hesitant to provide capital, as they would have no way to verify the health of a company.

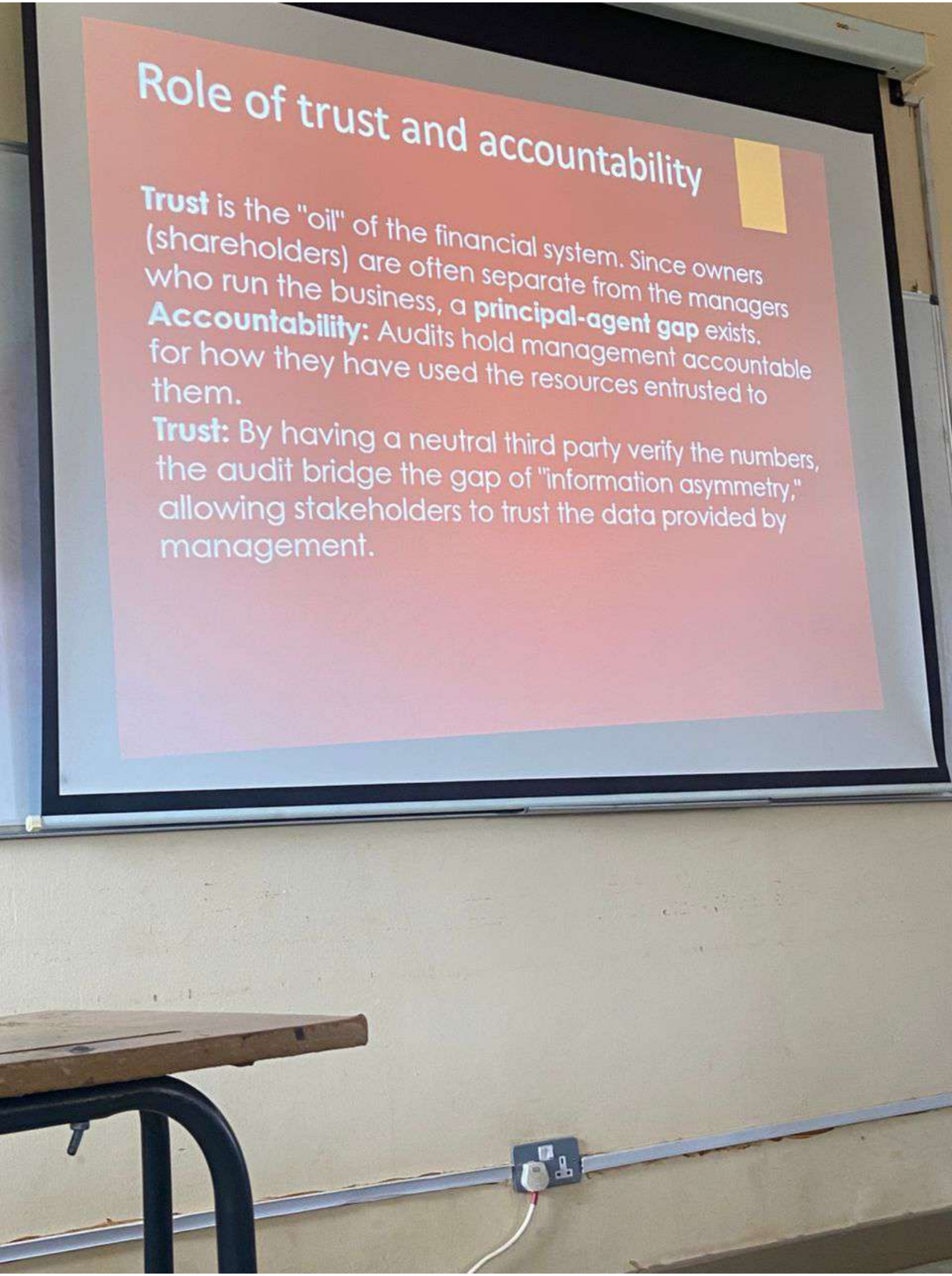

Why Audits are needed
• Verification of Accuracy: Ensures that financial reports are free from material misstatements, whether caused by error or fraud.
• Compliance & Regulation: Confirms that the organization is adhering to statutory laws, tax regulations, and industry-specific standards.

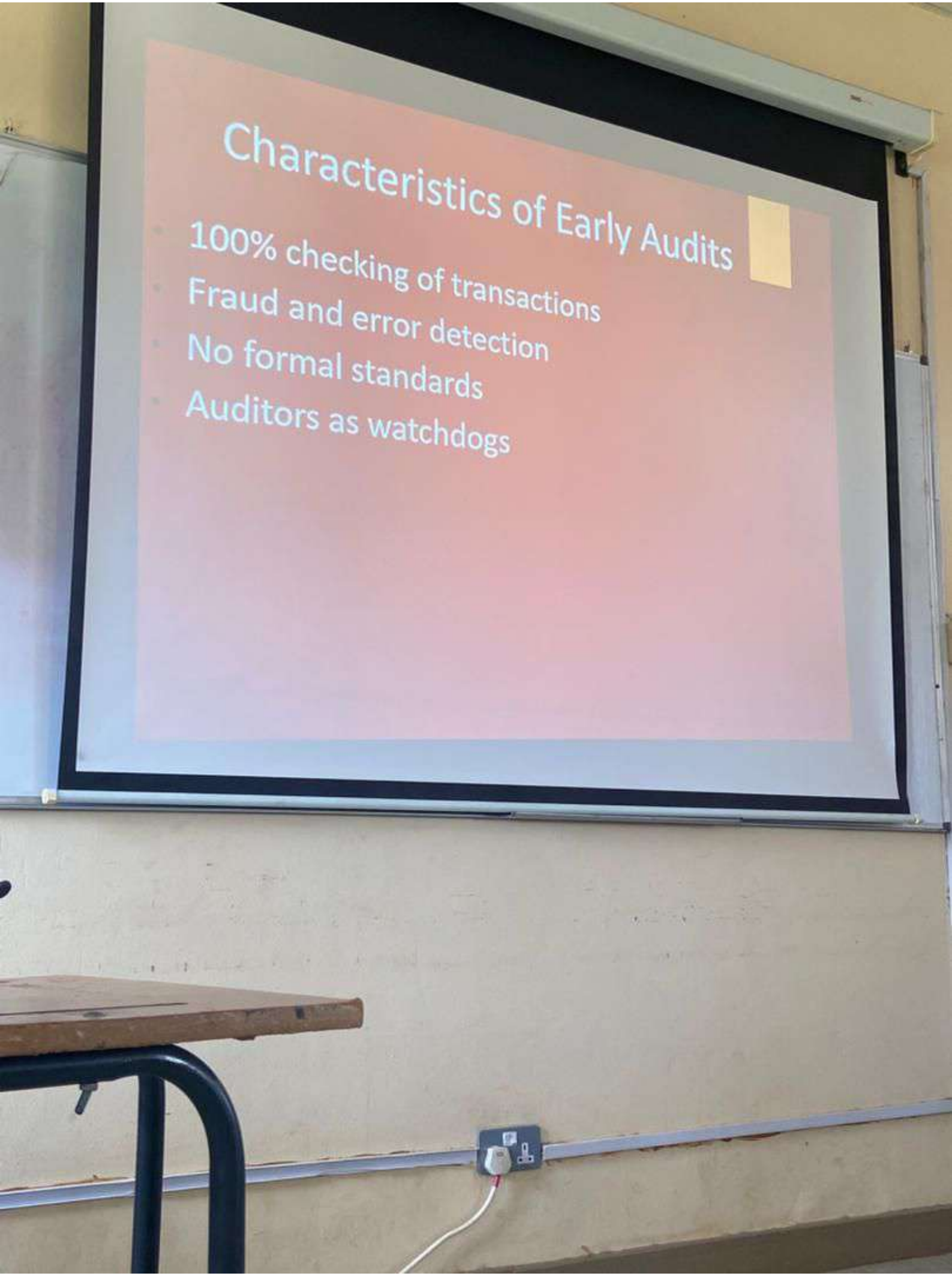

Why Audits are needed
• Risk Management: Identifies weaknesses in internal controls and provides a roadmap for improving organizational efficiency.
• Investor Confidence: Acts as a "seal of approval" that allows the public to trust the financial health of an institution.


Users of Audited Information
Government and Tax Authorities: To ensure that the correct amount of tax is being declared and paid.
Employees: To gauge the stability and future viability of their employer.
Management: To confirm that their internal systems are functioning correctly and to identify areas for improvement.


Early Origins of Auditing (Pre-1900)
Auditing in ancient civilizations
Used by kings, churches, and merchants
Focus on cash and stewardship

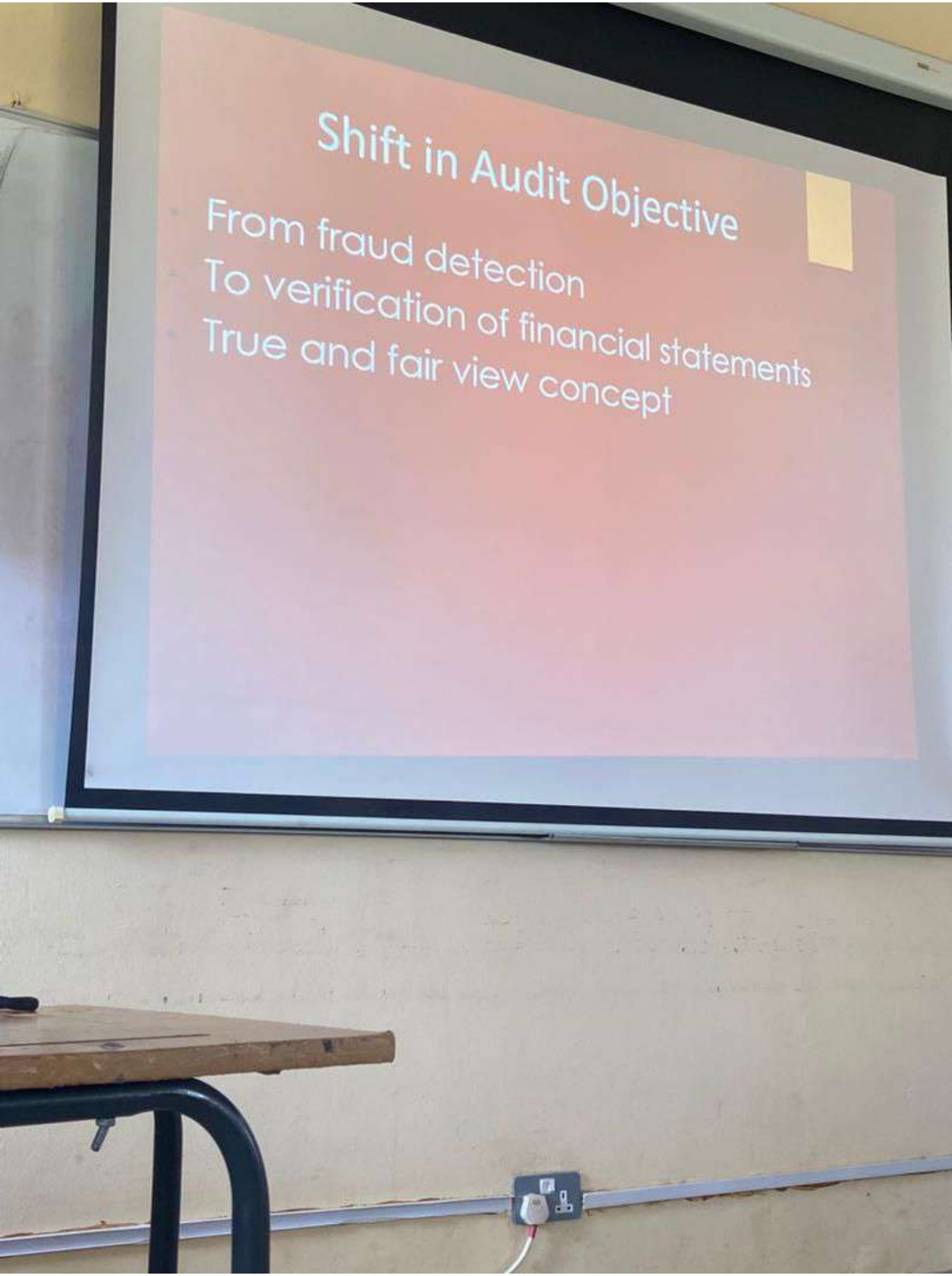

Users of Audited Information
Different groups rely on the audit report for various decision-making purposes:
Shareholders/Investors: To decide whether to buy, hold, or sell shares in a company.
Lenders and Banks: To assess the creditworthiness of an entity before approving loans.


Role of trust and accountability
Trust is the "oil" of the financial system. Since owners (shareholders) are often separate from the managers who run the business, a principal-agent gap exists.
Accountability: Audits hold management accountable for how they have used the resources entrusted to them.
Trust: By having a neutral third party verify the numbers, the audit bridge the gap of "information asymmetry," allowing stakeholders to trust the data provided by management.


Characteristics of Early Audits
100% checking of transactions
Fraud and error detection
No formal standards
Auditors as watchdogs

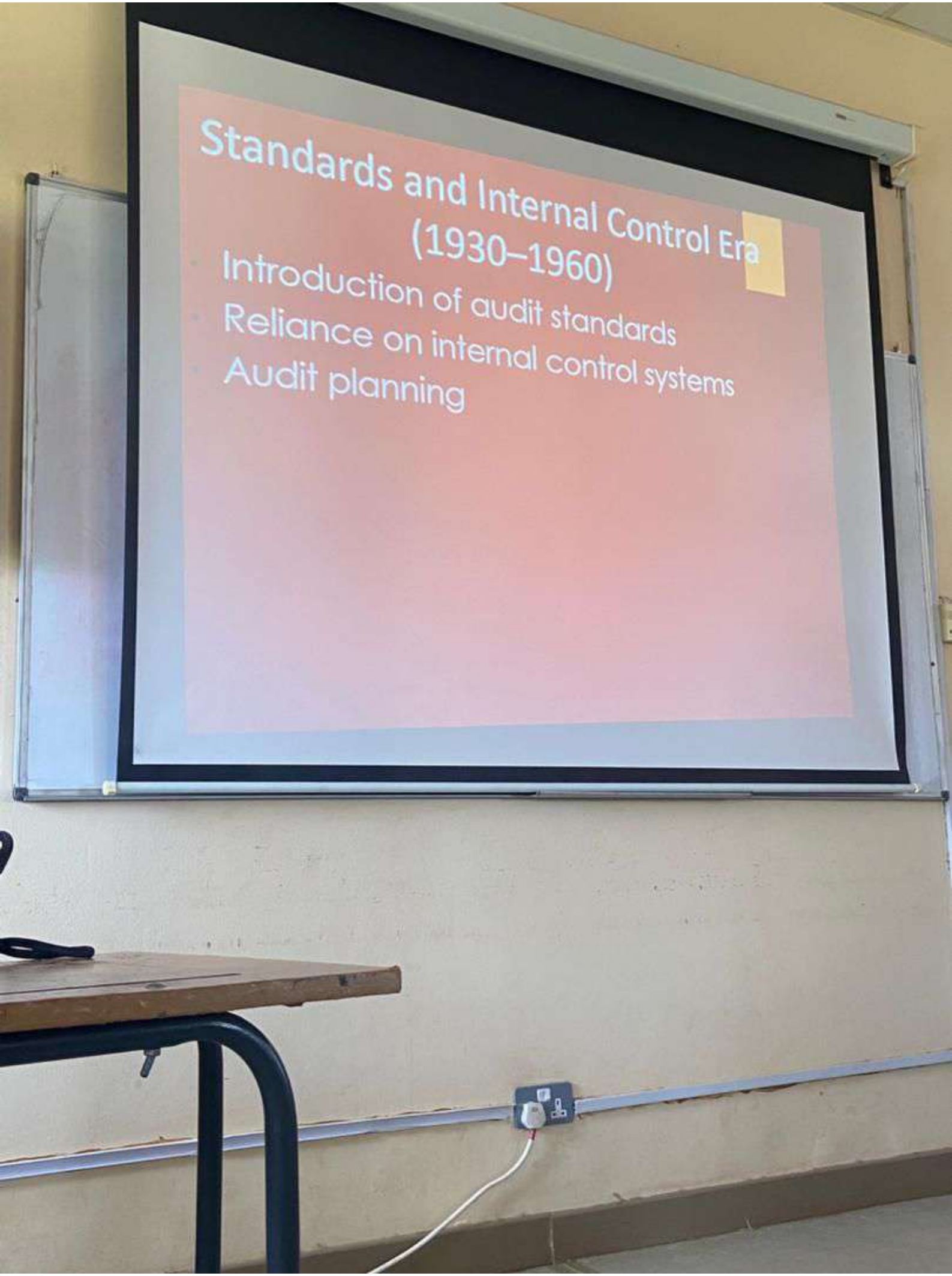

Limitations of Early Auditing
Time consuming
Inefficient for large entities
Limited business insight
Reactive rather than proactive


Industrial Revolution (1900–1930)
Growth of corporations
Separation of ownership and management
Need for independent audits

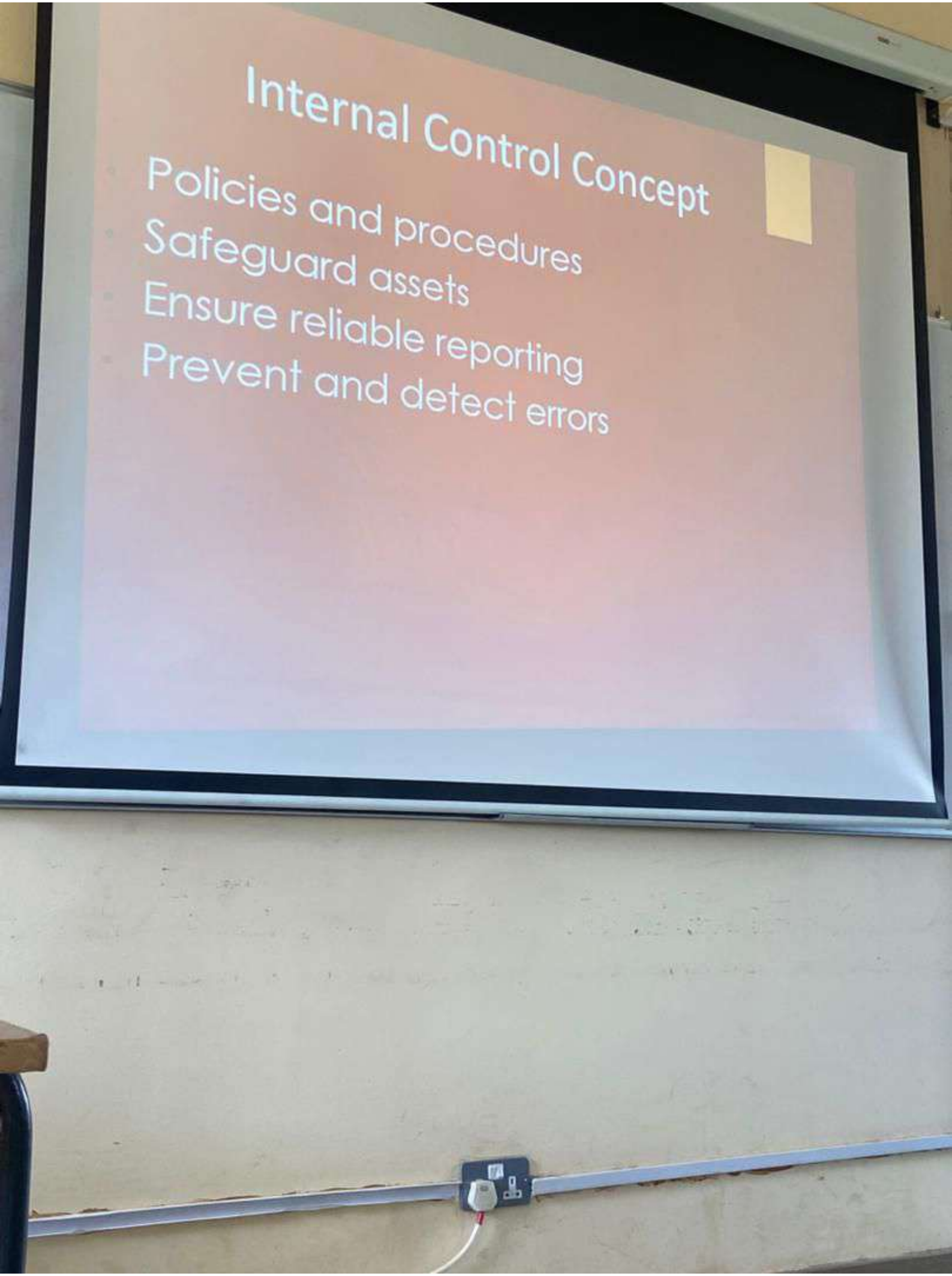

Shift in Audit Objective
From fraud detection
To verification of financial statements
True and fair view concept

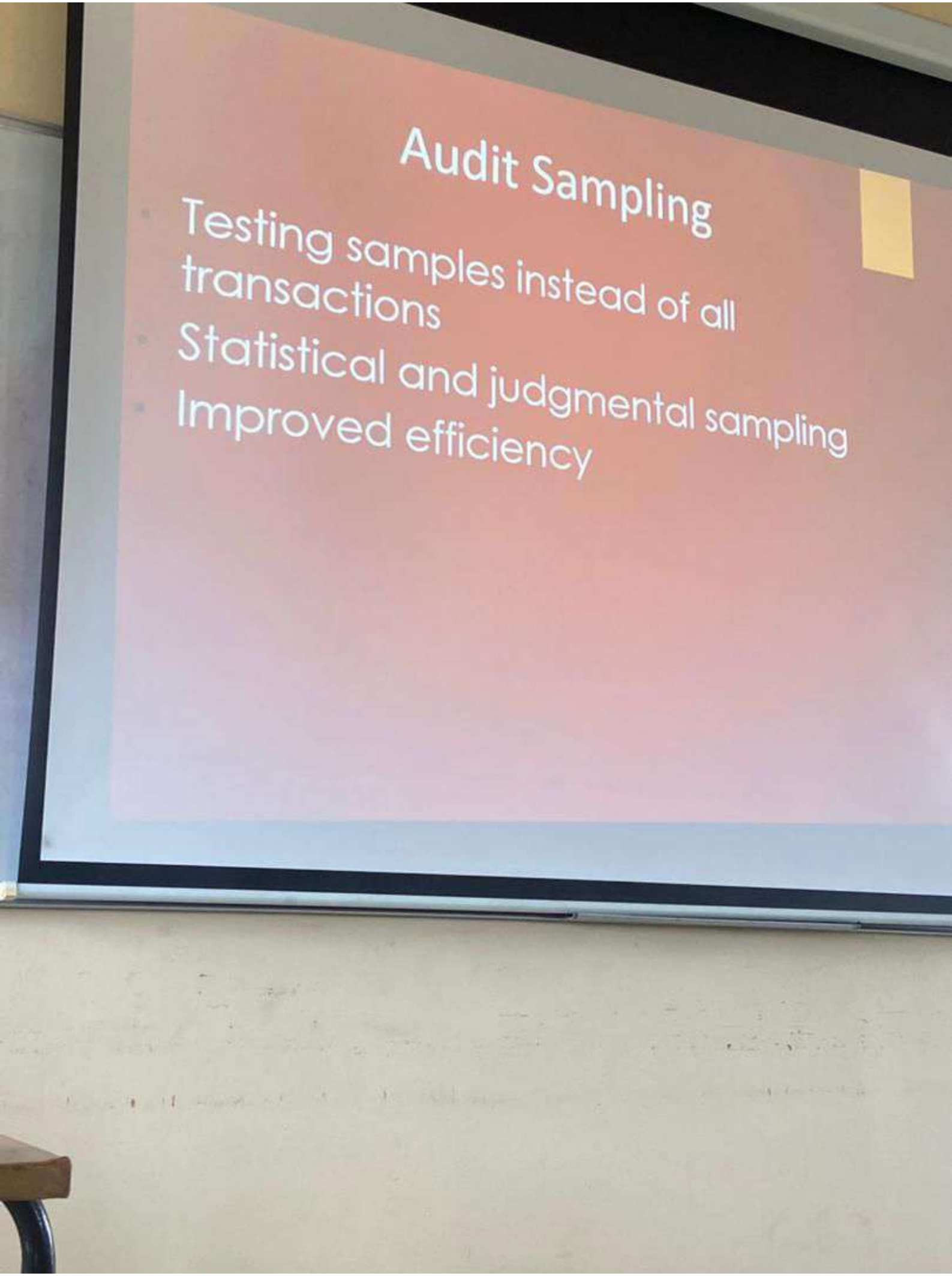

Development of Professional Bodies
Formation of accounting institutes
Standardization of practice
Recognition of auditors as professionals

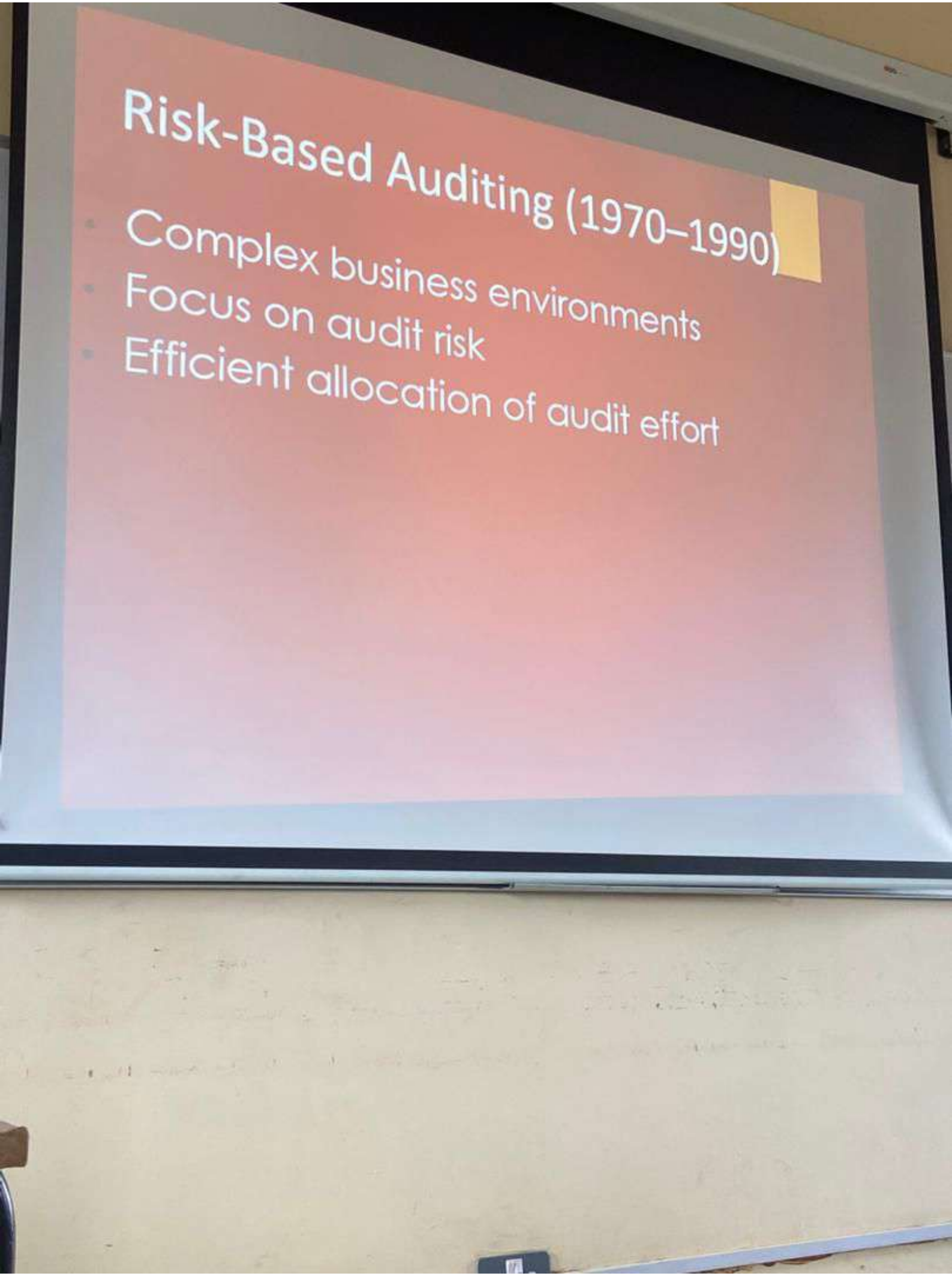

Great Depression & Regulation
(1930s)
Corporate collapses
Loss of investor confidence
Government intervention


Standards and Internal Control Era
(1930–1960)
Introduction of audit standards
Reliance on internal control systems
Audit planning


Reference
Information Technology Control and Audit.
Angel Otero. 5edn


Internal Control Concept
Policies and procedures
Safeguard assets
Ensure reliable reporting
Prevent and detect errors

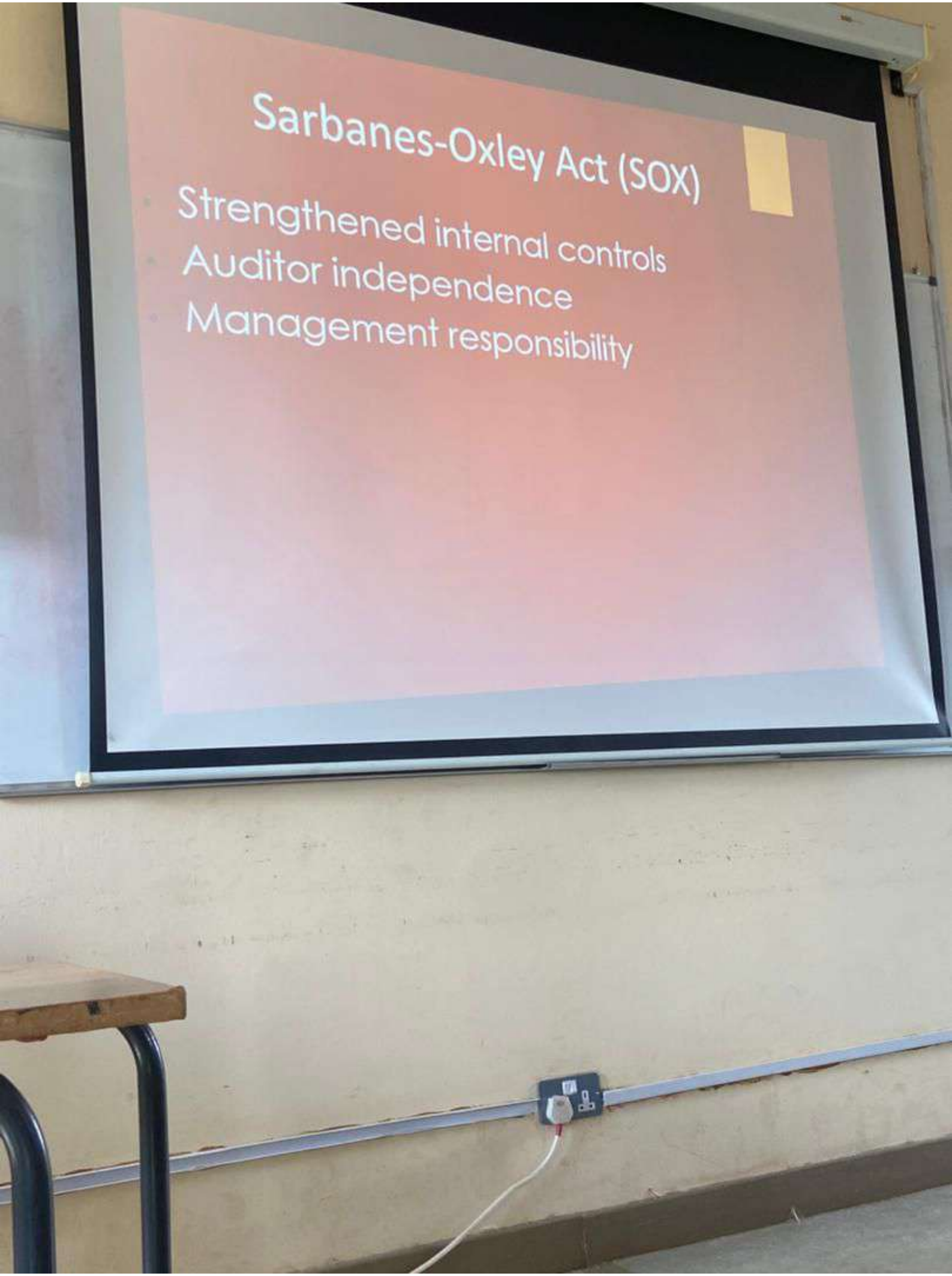

Audit Sampling
Testing samples instead of all transactions
Statistical and judgmental sampling
Improved efficiency

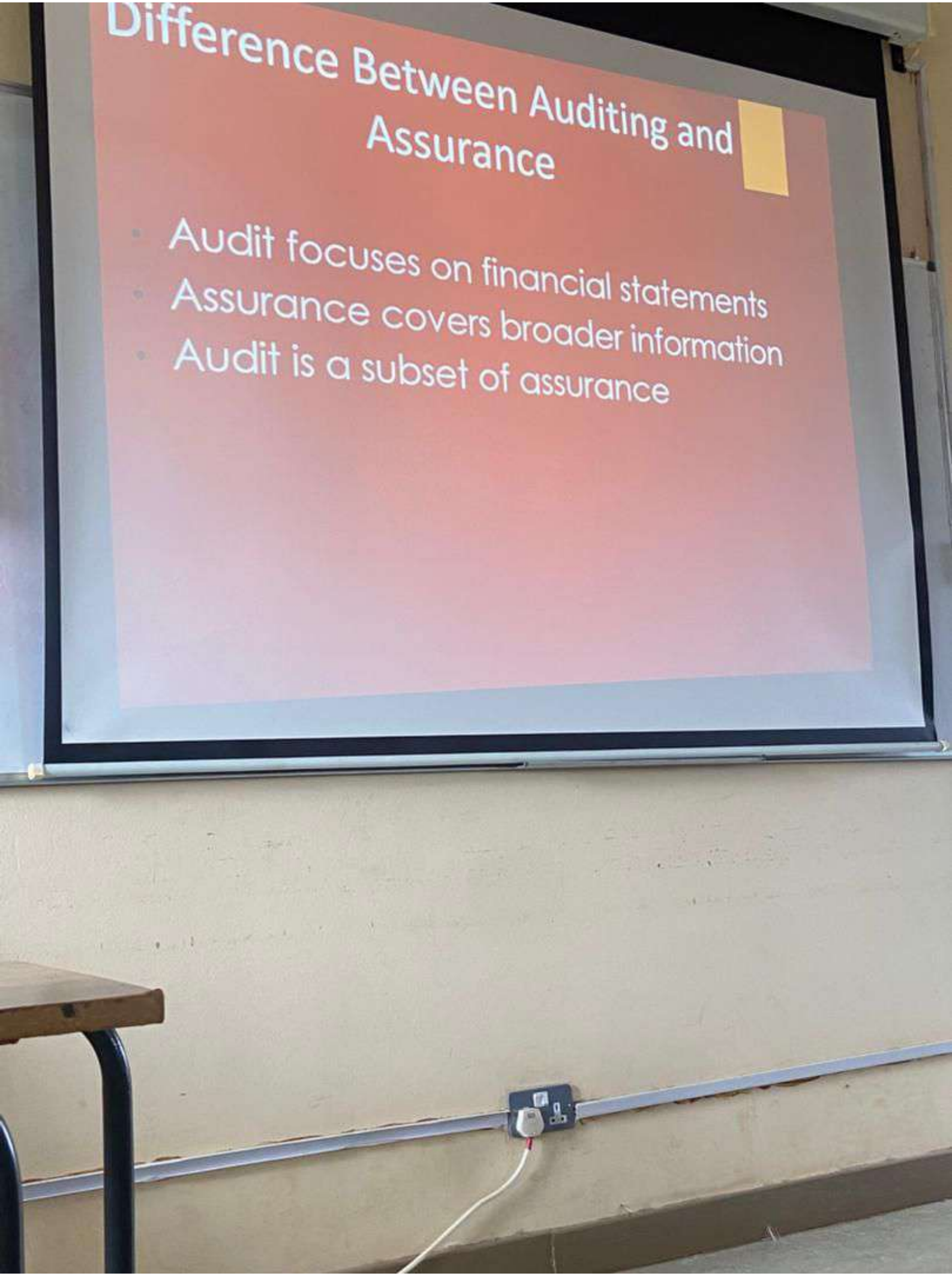

Risk-Based Auditing (1970–1990)
Complex business environments
Focus on audit risk
Efficient allocation of audit effort

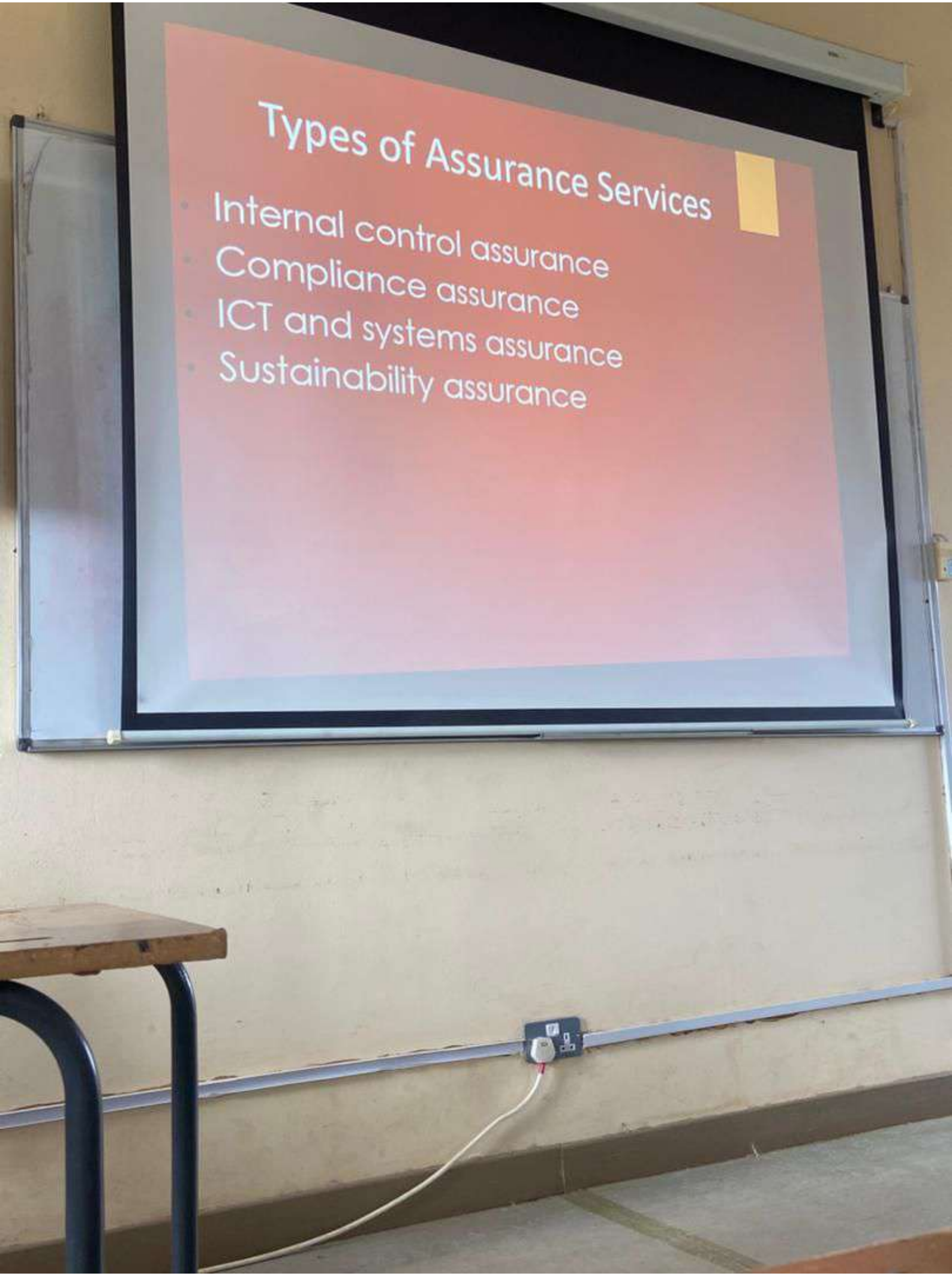

Emergence of Assurance Services
Stakeholders demand more than financial audits
Need assurance on systems and processes
Expansion of auditor role

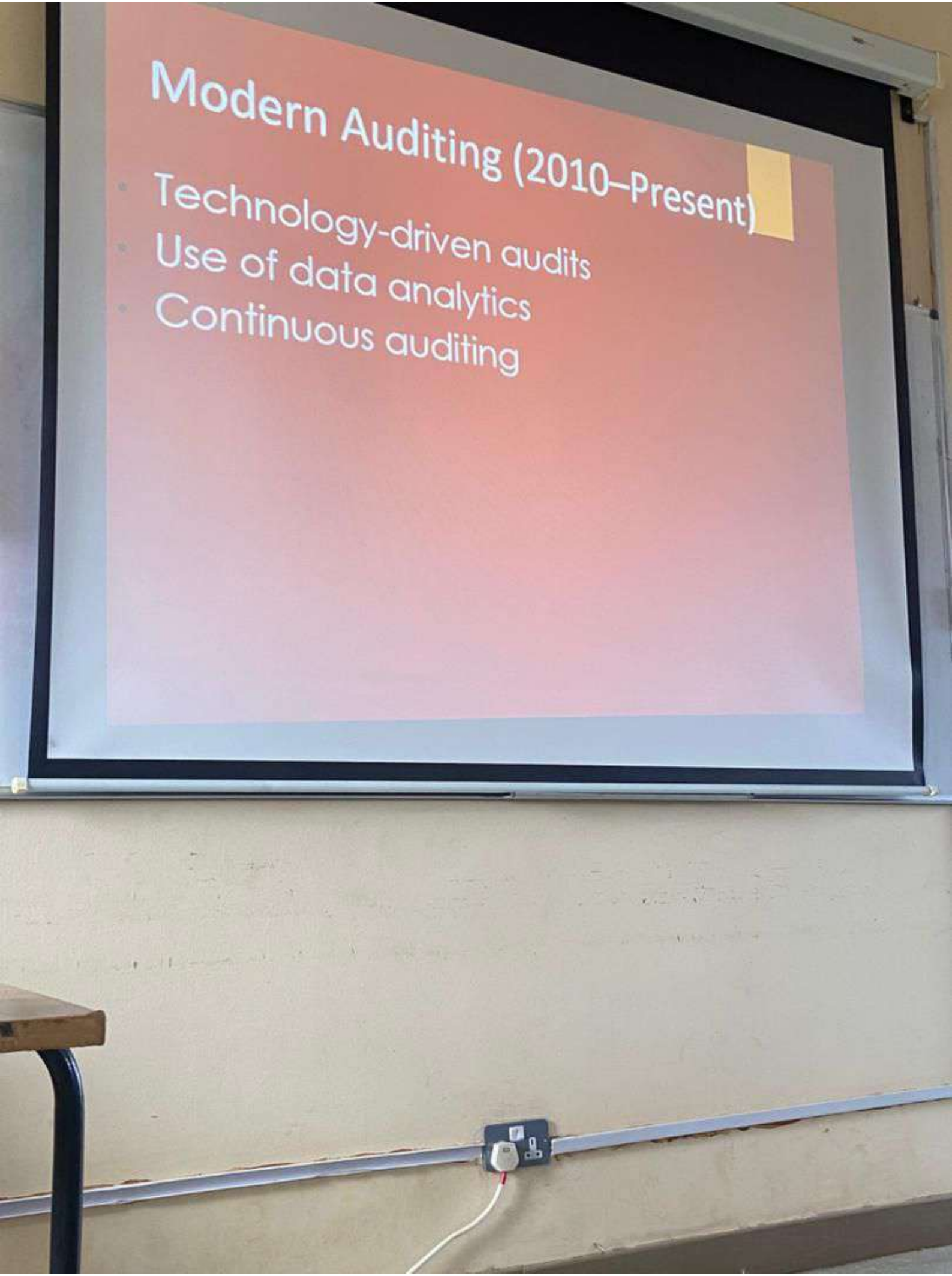

Corporate Scandals (2000–2010)
Enron
WorldCom
Parmalat


Impact of Corporate Scandals
Loss of public trust
Failure of self-regulation
Stricter laws

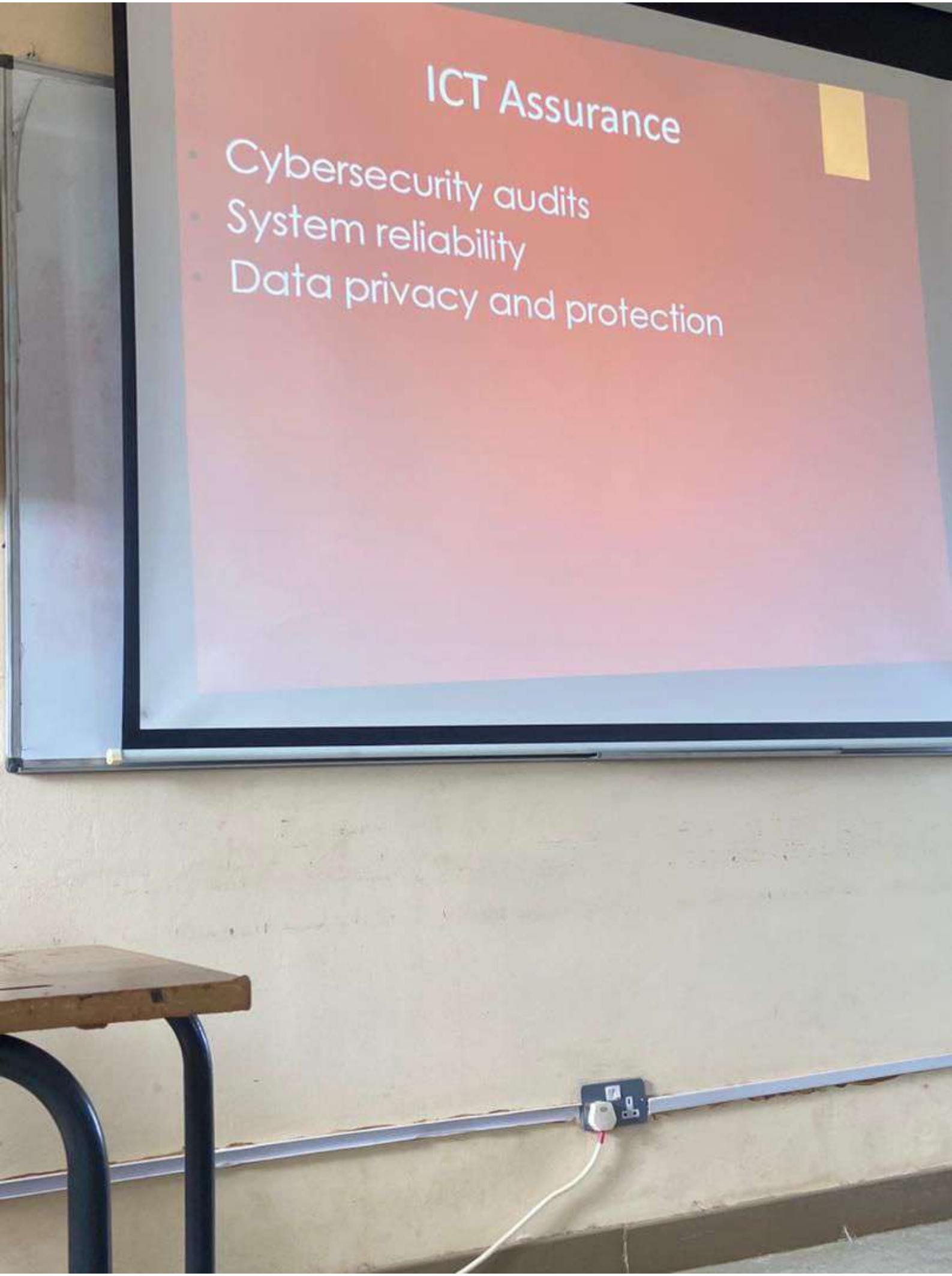

Sarbanes-Oxley Act (SOX)
Strengthened internal controls
Auditor independence
Management responsibility


Difference Between Auditing and Assurance
Audit focuses on financial statements
Assurance covers broader information
Audit is a subset of assurance


Types of Assurance Services
Internal control assurance
Compliance assurance
ICT and systems assurance
Sustainability assurance

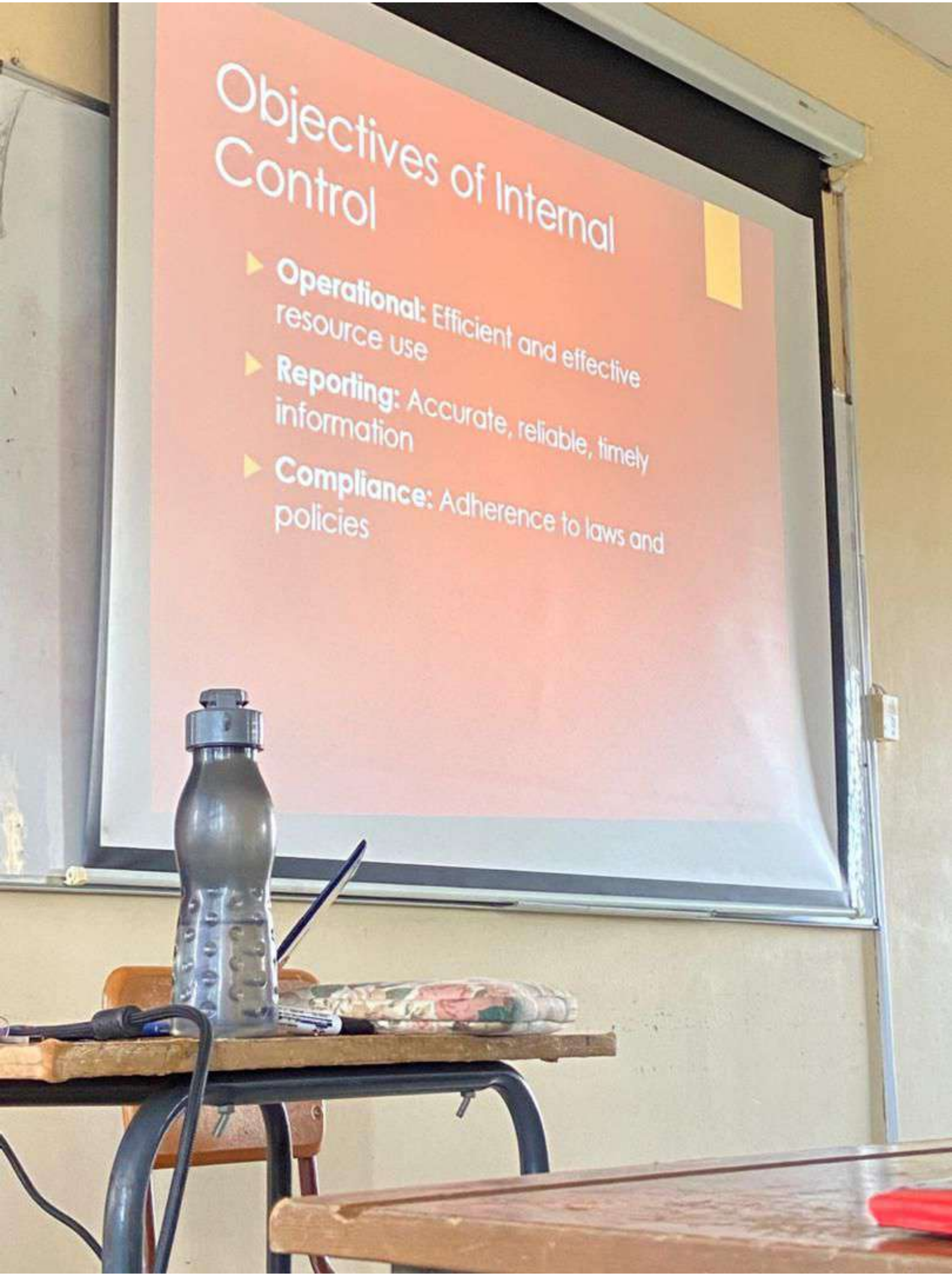

Modern Auditing (2010–Present)
Technology-driven audits
Use of data analytics
Continuous auditing


Role of Technology in Auditing
Computer Assisted Audit Techniques (CAATs)
Big data analytics
Artificial intelligence


ICT Assurance
Cybersecurity audits
System reliability
Data privacy and protection


Sustainability & ESG Assurance
Environmental, social, and governance- ESG
Environmental reporting
Social responsibility
Governance assurance


Internal Control- What is it?
Process implemented by management and staff
Provides reasonable assurance in achieving objectives
Applies to operations, reporting, and compliance
Involves policies, procedures, and activities
Helps prevent fraud, errors, inefficiencies
Continuous and dynamic process


Objectives of Internal Control
Operational: Efficient and effective resource use
Reporting: Accurate, reliable, timely information
Compliance: Adherence to laws and policies

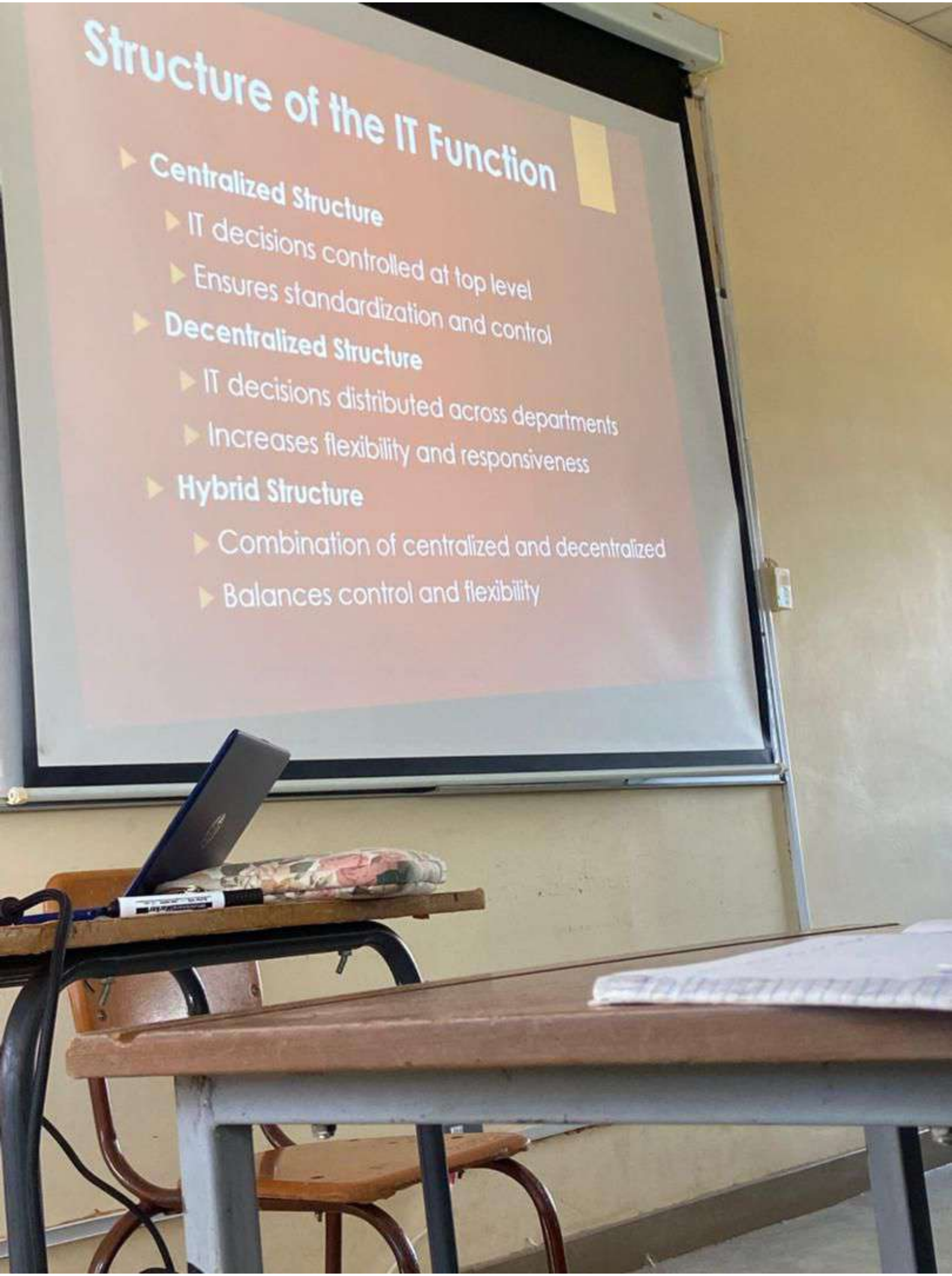

Principles of Internal Control
Segregation of duties
Authorization
Documentation
Physical controls
Independent checks
Monitoring


Internal Control Models
COSO: Control Environment, Risk Assessment, Control Activities, Information & Communication, Monitoring
COBIT: IT governance and alignment
ISO 31000: Risk management guidelines


Importance of Internal Control
Enhances accountability and transparency
Reduces fraud and errors
Improves decision-making
Ensures compliance
Strengthens performance

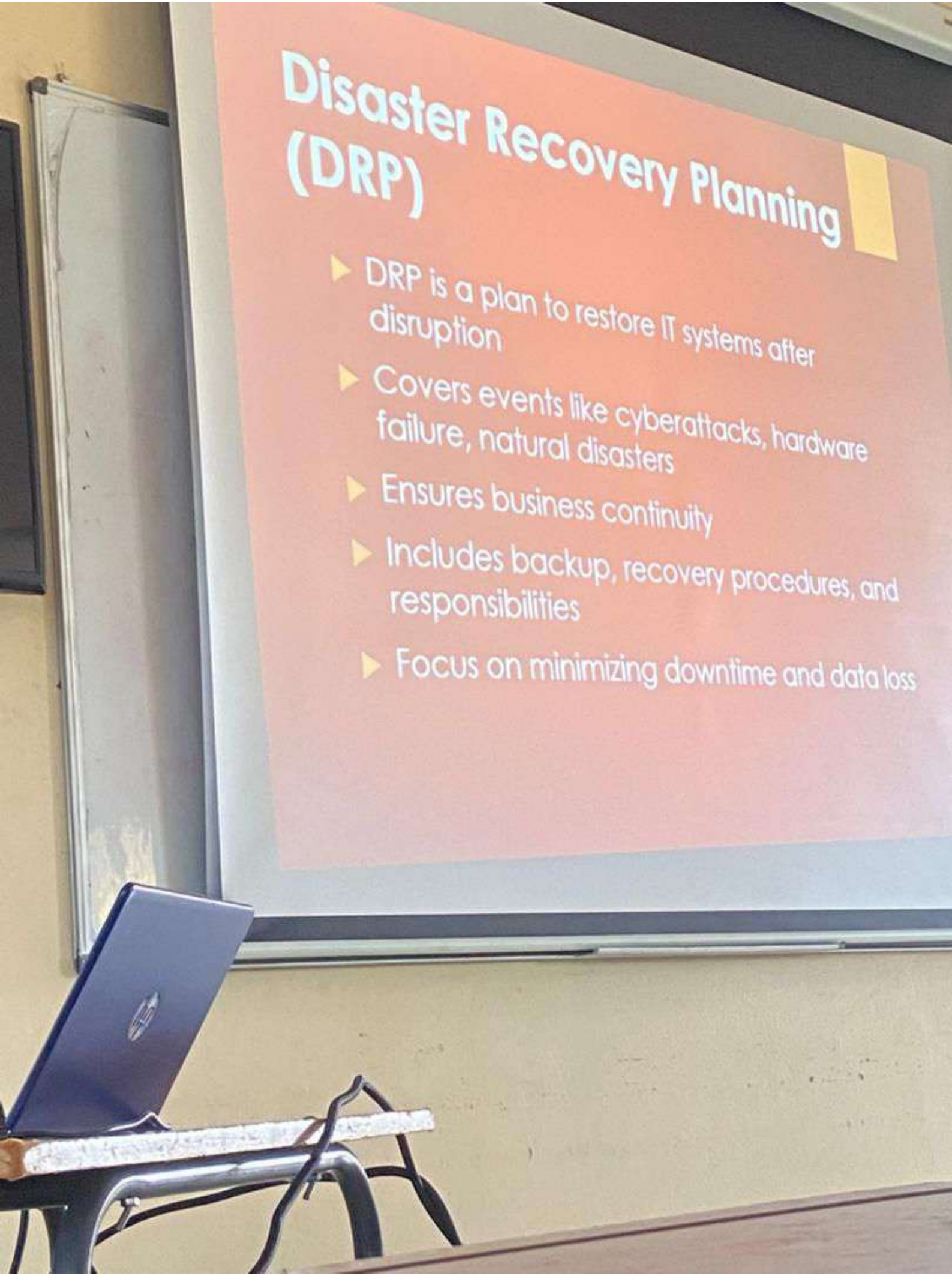

Information Technology Governance
IT governance ensures IT supports business goals
Focuses on value delivery, risk management, and performance
Aligns IT strategy with organizational objectives
Defines decision rights and accountability
Uses frameworks like COBIT and ISO/IEC 38500
Promotes transparency and compliance

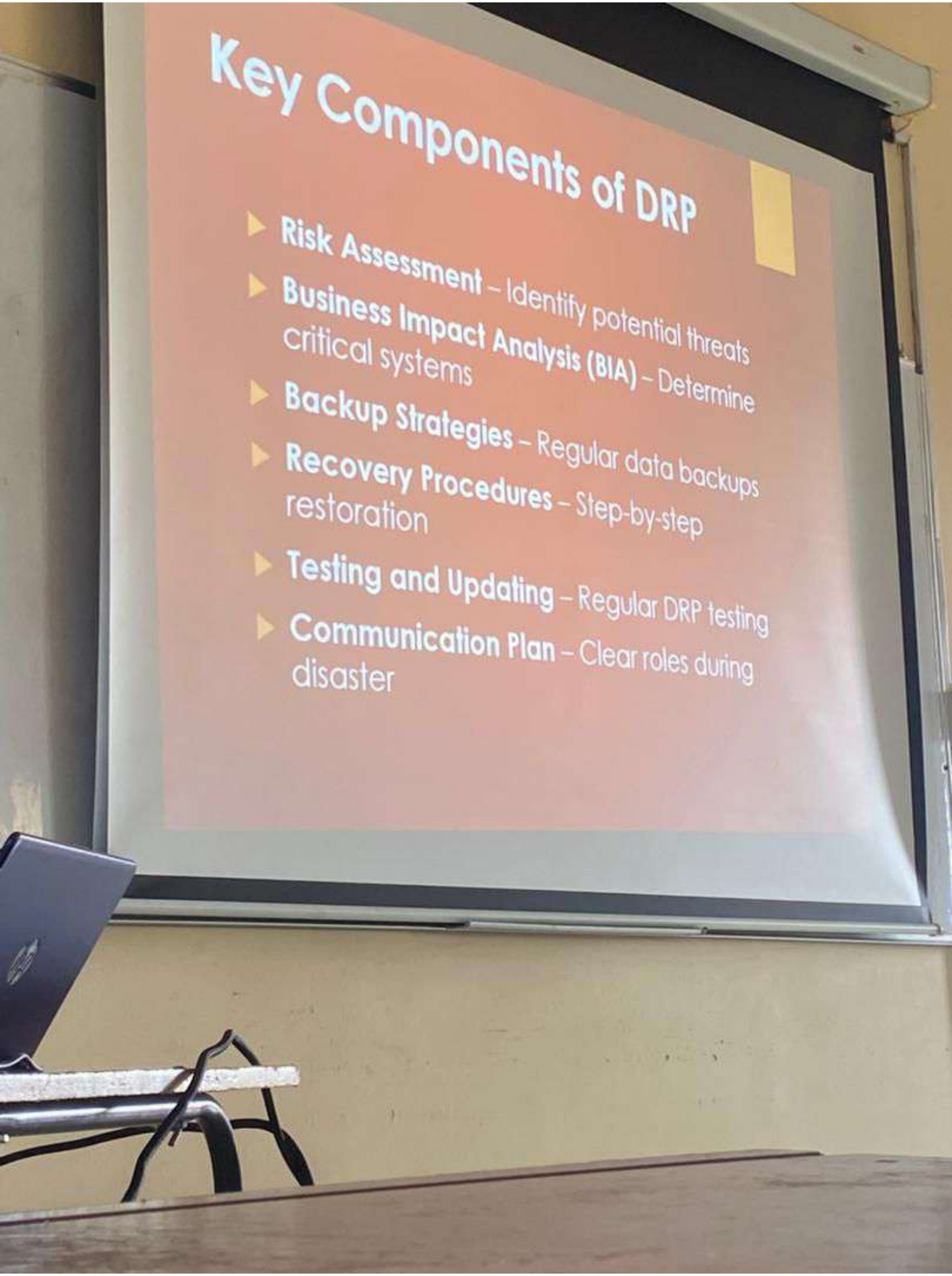

Objectives of IT Governance
Ensure alignment between IT and business strategy
Deliver value from IT investments
Manage IT-related risks effectively
Optimize resource utilization
Measure IT performance and outcomes

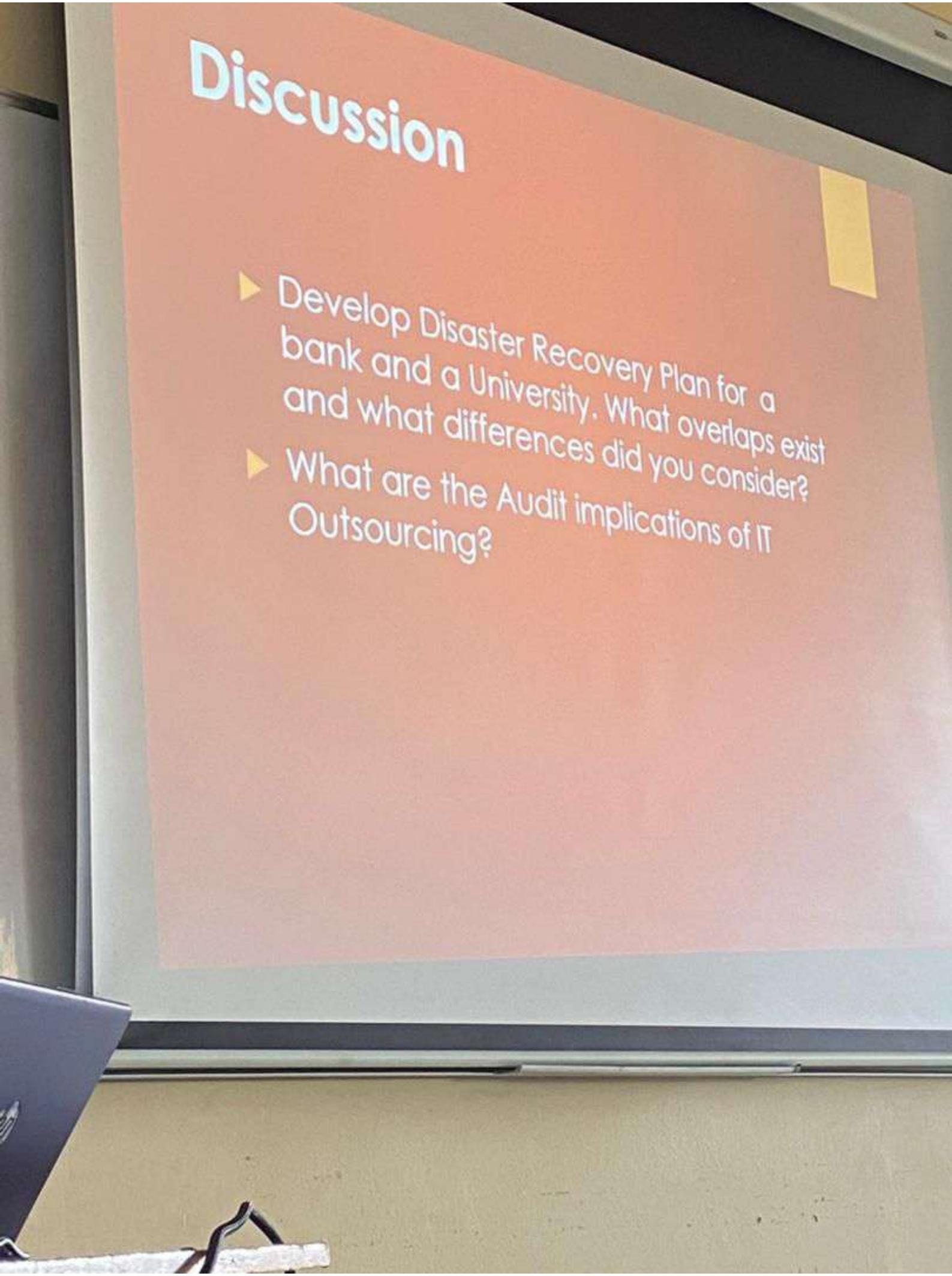

Structure of the IT Function
Centralized Structure
IT decisions controlled at top level
Ensures standardization and control
Decentralized Structure
IT decisions distributed across departments
Increases flexibility and responsiveness
Hybrid Structure
Combination of centralized and decentralized
Balances control and flexibility

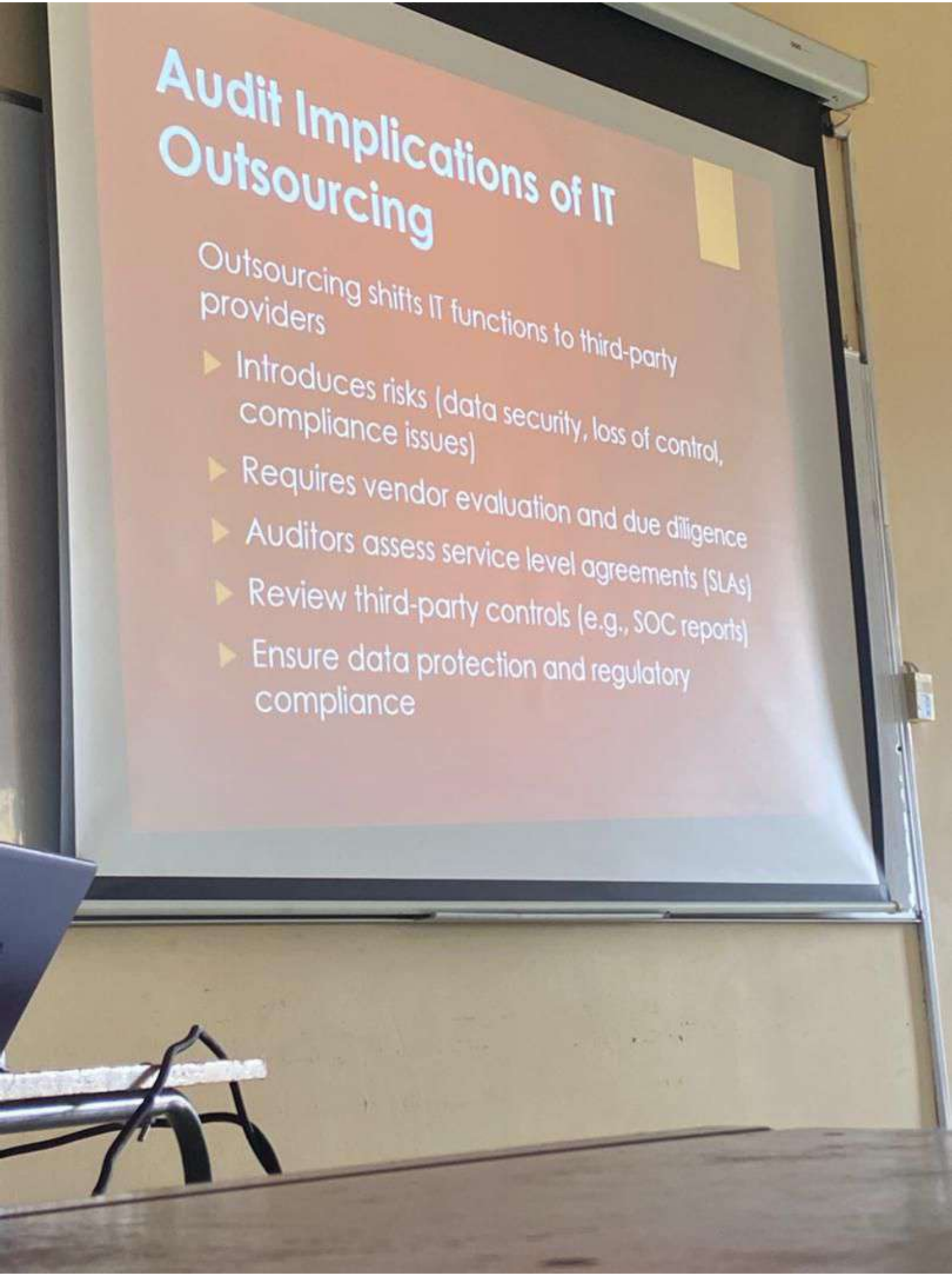

Key Roles in IT Function
Chief Information Officer (CIO) – Strategic IT leadership
IT Managers – Oversee operations and projects
System Administrators – Maintain IT systems
Network Administrators – Manage networks
Security Officers – Ensure cybersecurity
End Users – Use systems for daily operations

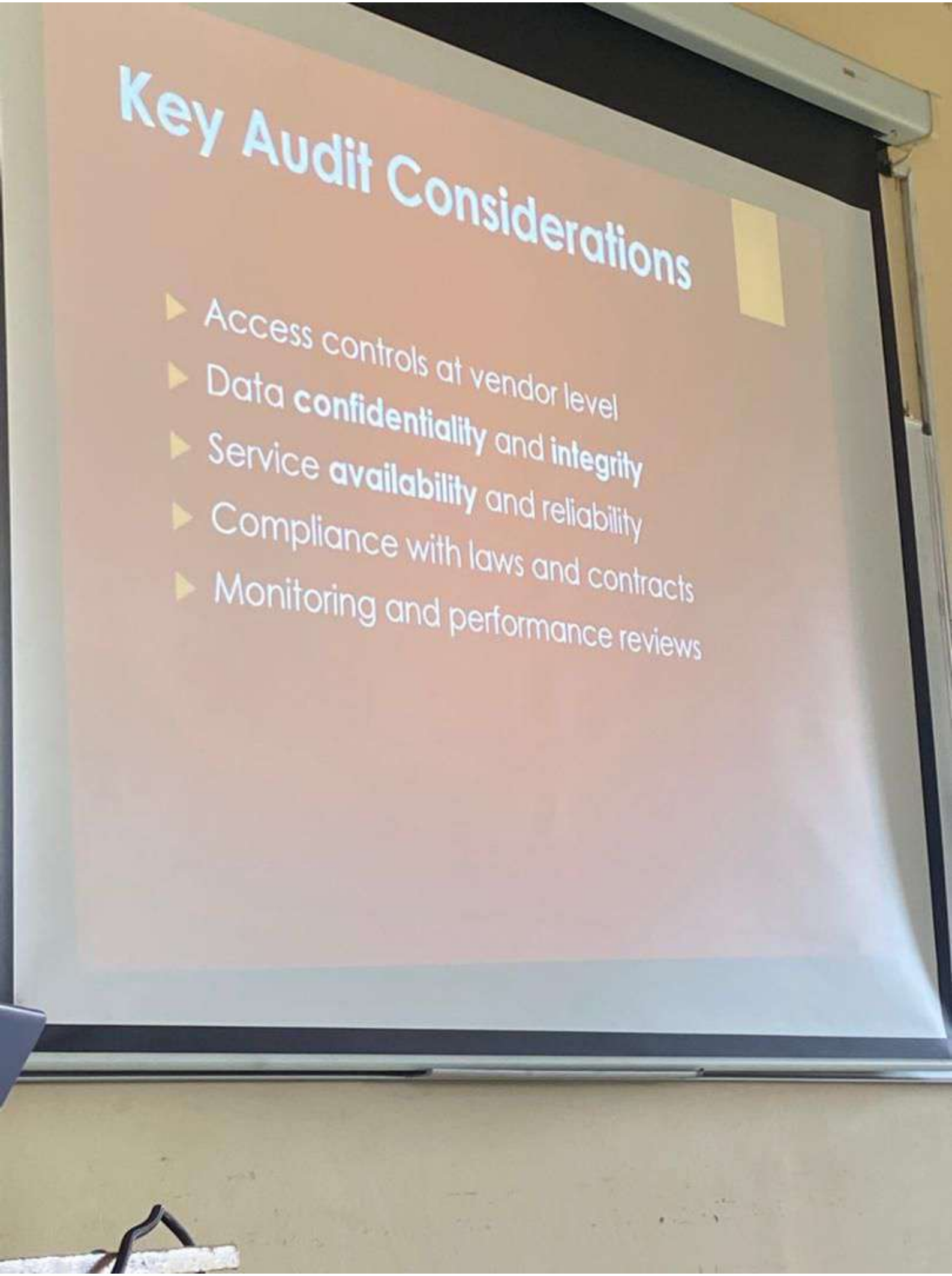

Key Roles in IT Function
Chief Information Officer (CIO) – Strategic IT leadership
IT Managers – Oversee operations and projects
System Administrators – Maintain IT systems
Network Administrators – Manage networks
Security Officers – Ensure cybersecurity
End Users – Use systems for daily operations


Disaster Recovery Planning (DRP)
DRP is a plan to restore IT systems after disruption
Covers events like cyberattacks, hardware failure, natural disasters
Ensures business continuity
Includes backup, recovery procedures, and responsibilities
Focus on minimizing downtime and data loss

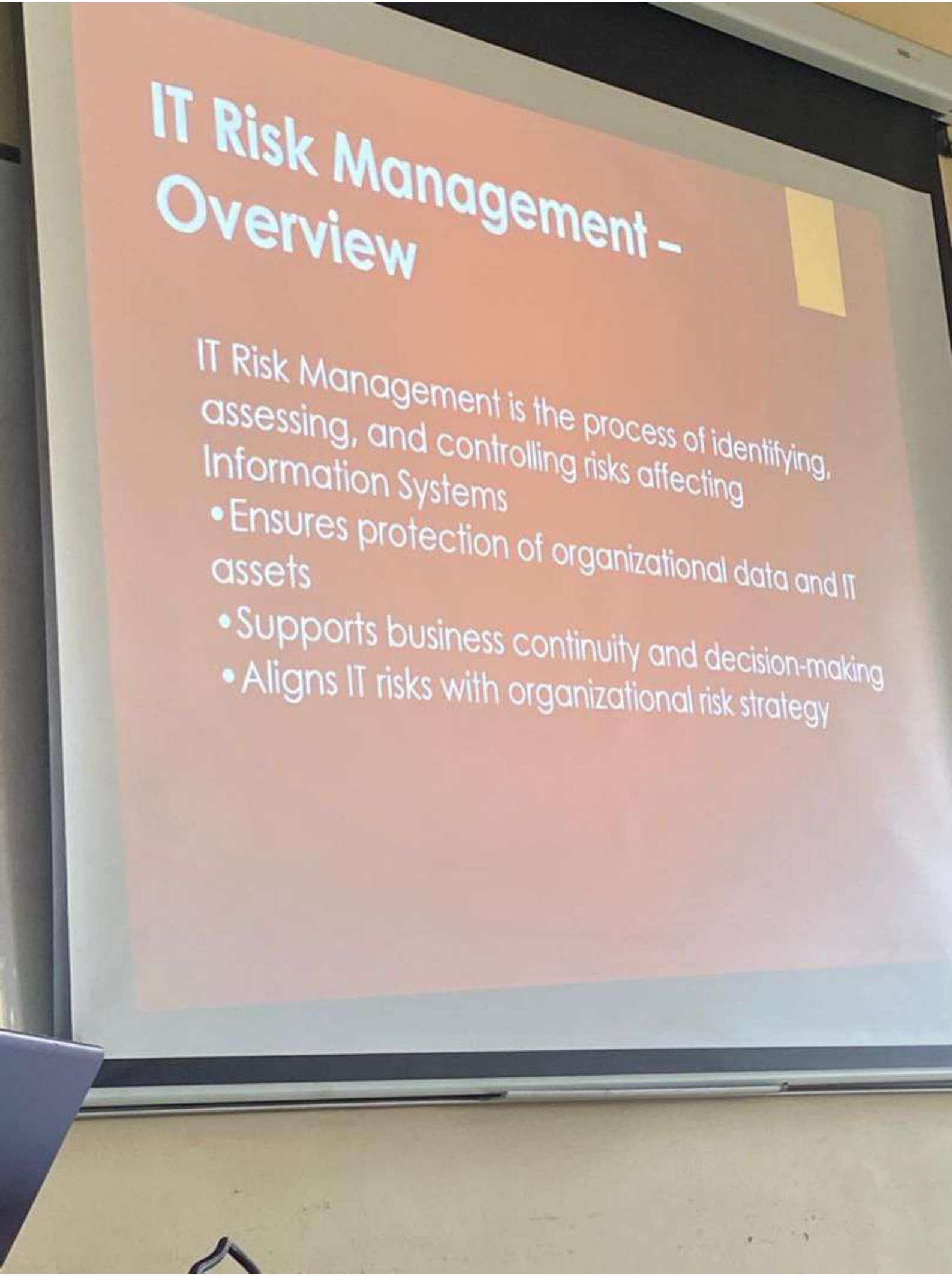

Key Components of DRP
Risk Assessment – Identify potential threats
Business Impact Analysis (BIA) – Determine critical systems
Backup Strategies – Regular data backups
Recovery Procedures – Step-by-step restoration
Testing and Updating – Regular DRP testing
Communication Plan – Clear roles during disaster

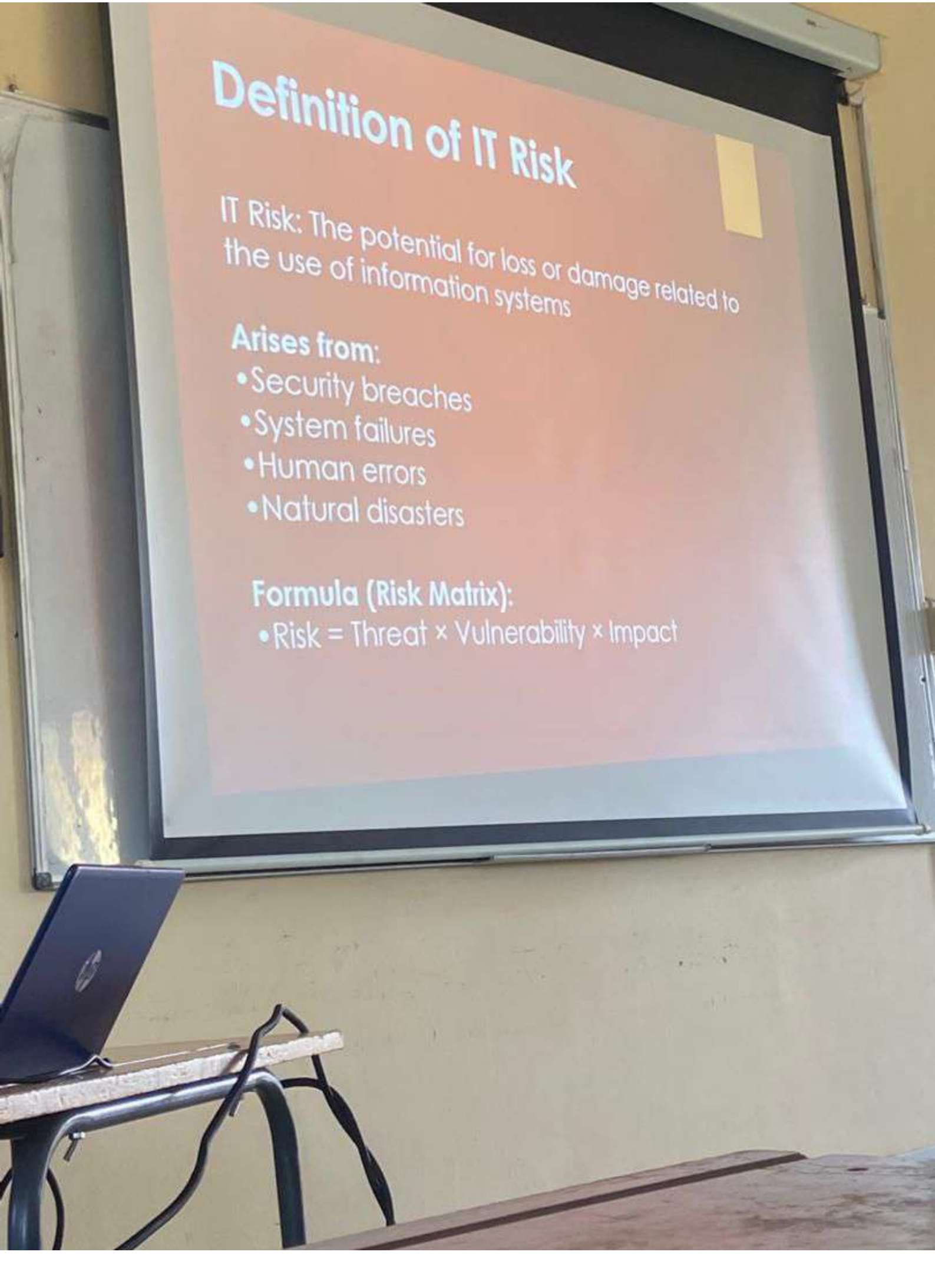

Discussion
Develop Disaster Recovery Plan for a bank and a University. What overlaps exist and what differences did you consider?
What are the Audit implications of IT Outsourcing?


Audit Implications of IT Outsourcing
Outsourcing shifts IT functions to third-party providers
Introduces risks (data security, loss of control, compliance issues)
Requires vendor evaluation and due diligence
Auditors assess service level agreements (SLAs)
Review third-party controls (e.g., SOC reports)
Ensure data protection and regulatory compliance


Key Audit Considerations
Access controls at vendor level
Data confidentiality and integrity
Service availability and reliability
Compliance with laws and contracts
Monitoring and performance reviews


IT Risk Managment

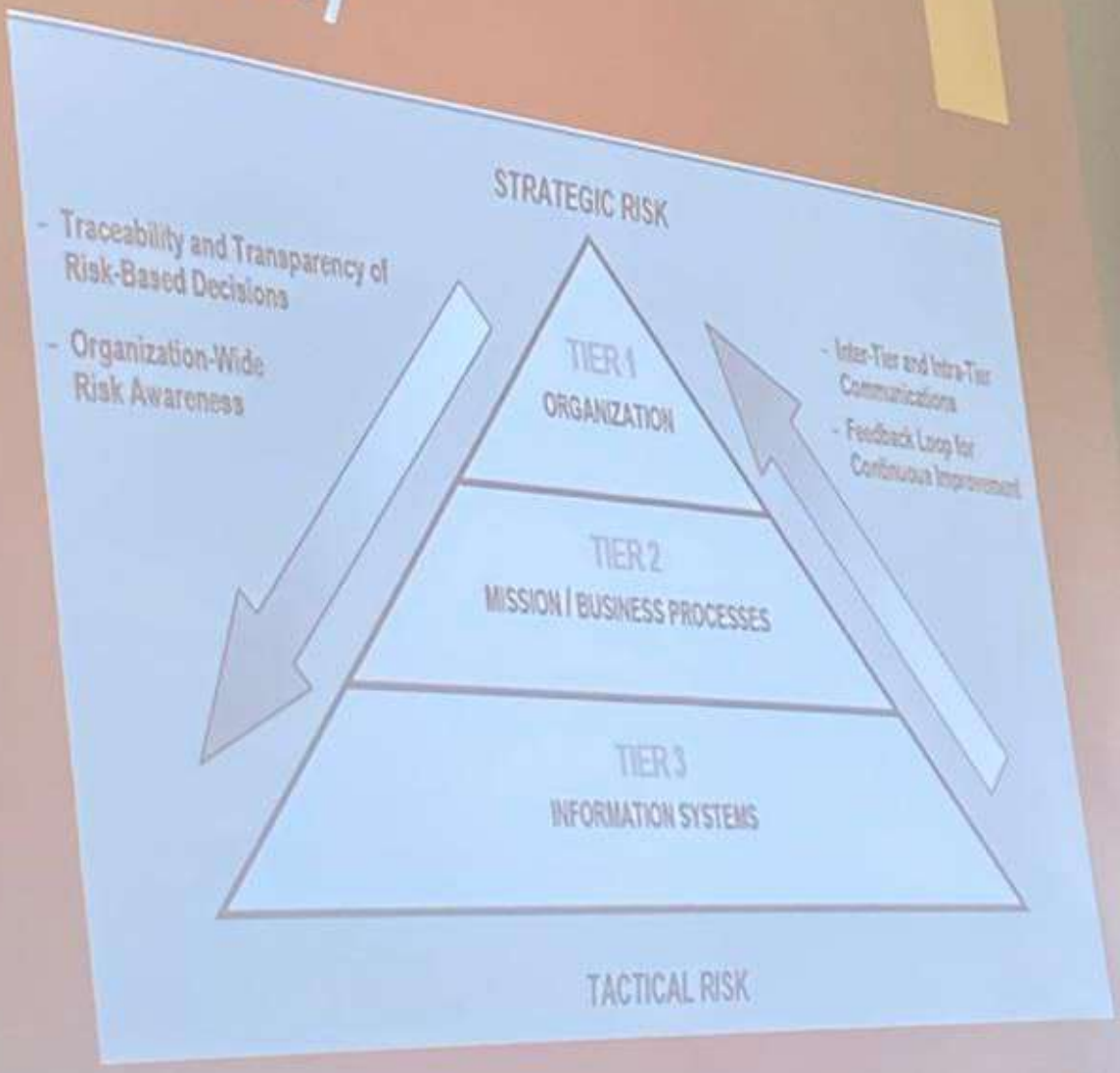

IT Risk Management – Overview
IT Risk Management is the process of identifying, assessing, and controlling risks affecting Information Systems
• Ensures protection of organizational data and IT assets
• Supports business continuity and decision-making
• Aligns IT risks with organizational risk strategy

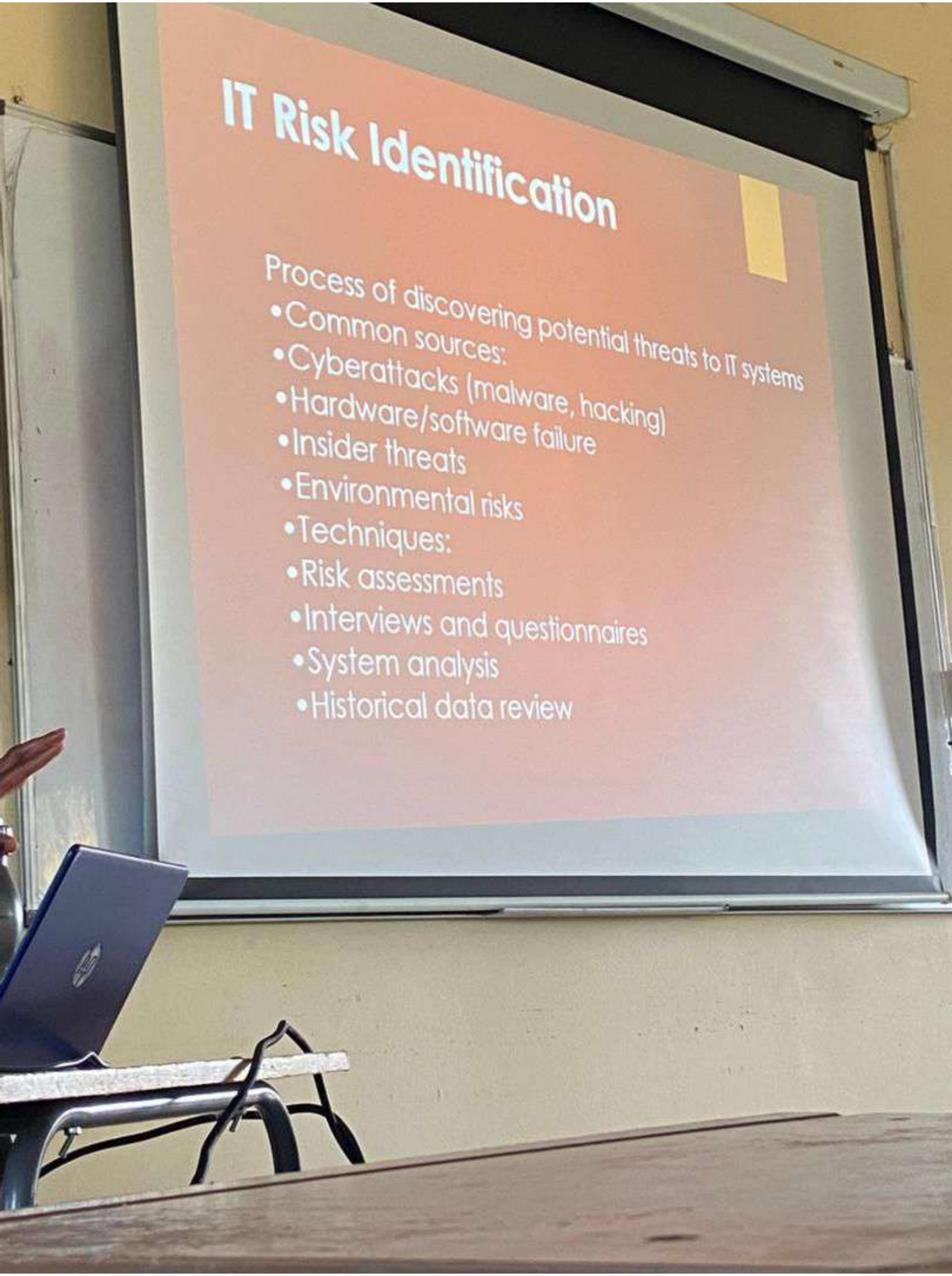

Definition of IT Risk
IT Risk: The potential for loss or damage related to the use of information systems
Arises from:
•Security breaches
•System failures
•Human errors
•Natural disasters
Formula (Risk Matrix):
•Risk = Threat × Vulnerability × Impact

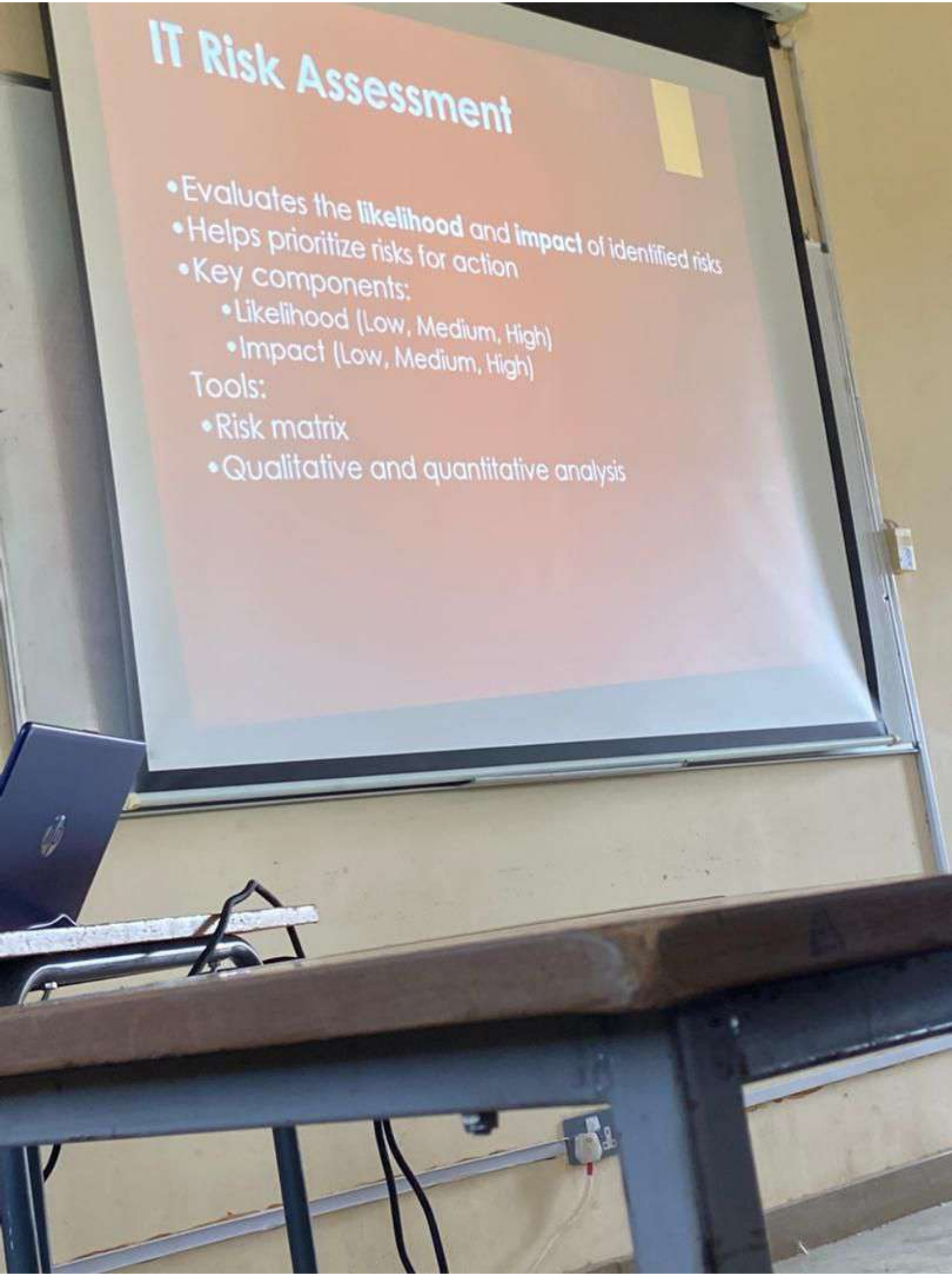

IT Risks may include:
Loss of data through accidental damage to computing equipment
Loss of data through theft of storage devices
Loss of data due to malfunctioning equipment
Failure of IT equipment
Network failure
Hackers having unauthorised access to IT systems
Intentional deletion of data
Unavailability of critical IT staff (expertise)

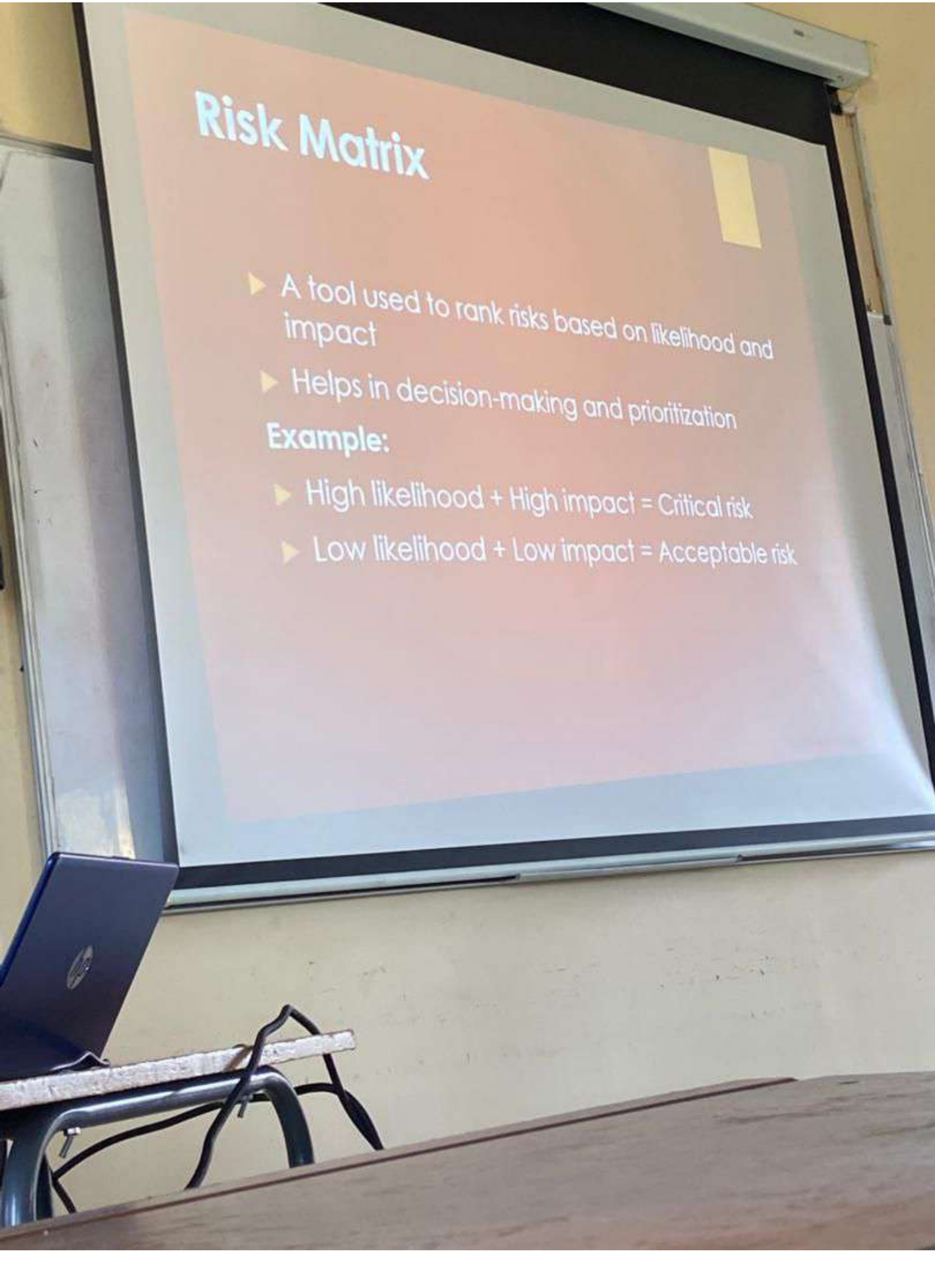

Importance of IT Risk Management
•Protects sensitive data
•Ensures system reliability
•Supports compliance with laws and standards
•Minimizes financial and reputational loss

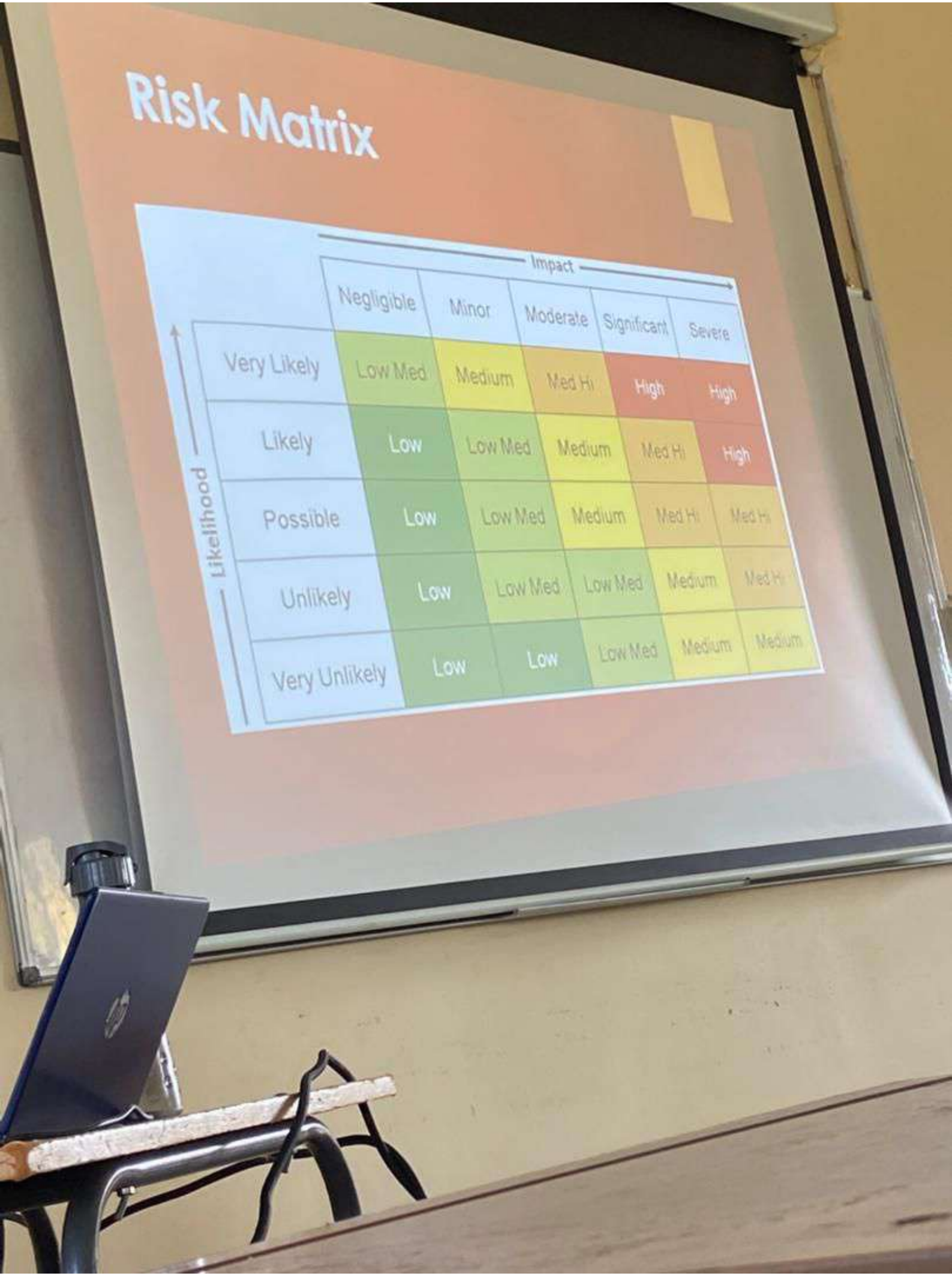
Risk Management Hierarchy




IT Risk Identification
Process of discovering potential threats to IT systems
•Common sources:
•Cyberattacks (malware, hacking)
•Hardware/software failure
•Insider threats
•Environmental risks
•Techniques:
•Risk assessments
•Interviews and questionnaires
•System analysis
•Historical data review

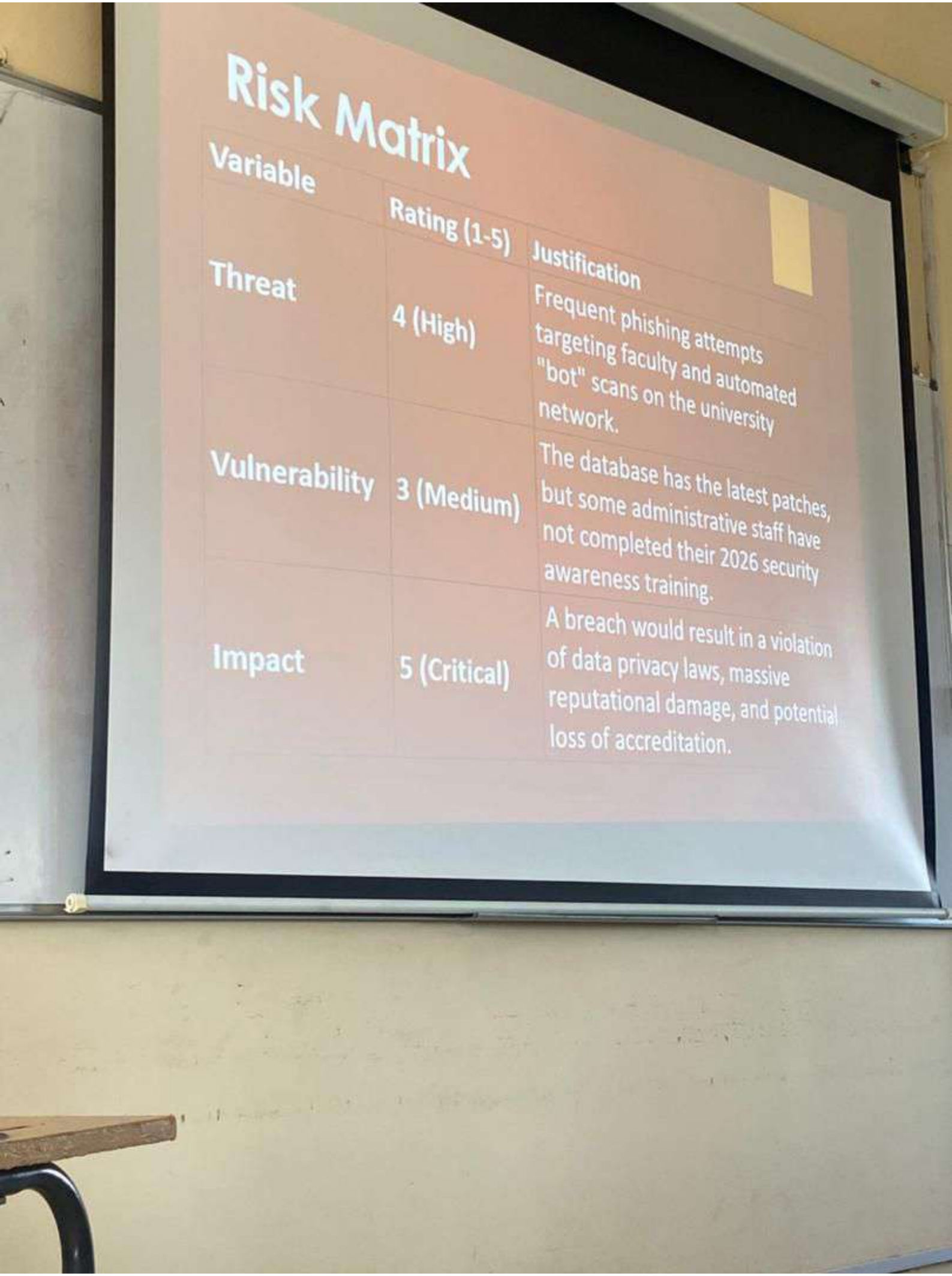

IT Risk Assessment
•Evaluates the likelihood and impact of identified risks
•Helps prioritize risks for action
•Key components:
•Likelihood (Low, Medium, High)
•Impact (Low, Medium, High)
Tools:
•Risk matrix
•Qualitative and quantitative analysis


Risk Matrix
A tool used to rank risks based on likelihood and impact
Helps in decision-making and prioritization
Example:
High likelihood + High impact = Critical risk
Low likelihood + Low impact = Acceptable risk


Risk Matrix
Impact
Likelihood
Negligible
Minor
Moderate
Significant
Severe
Very Likely
Likely
Possible
Unlikely
Very Unlikely
Low Med
Medium
Med Hi
High
Low
Low Med
Medium
Med Hi
High
Low
Low Med
Medium
Med Hi
Med Hi
Low
Low Med
Low Med
Medium
Med Hi
Low
Low
Low Med
Medium
Medium

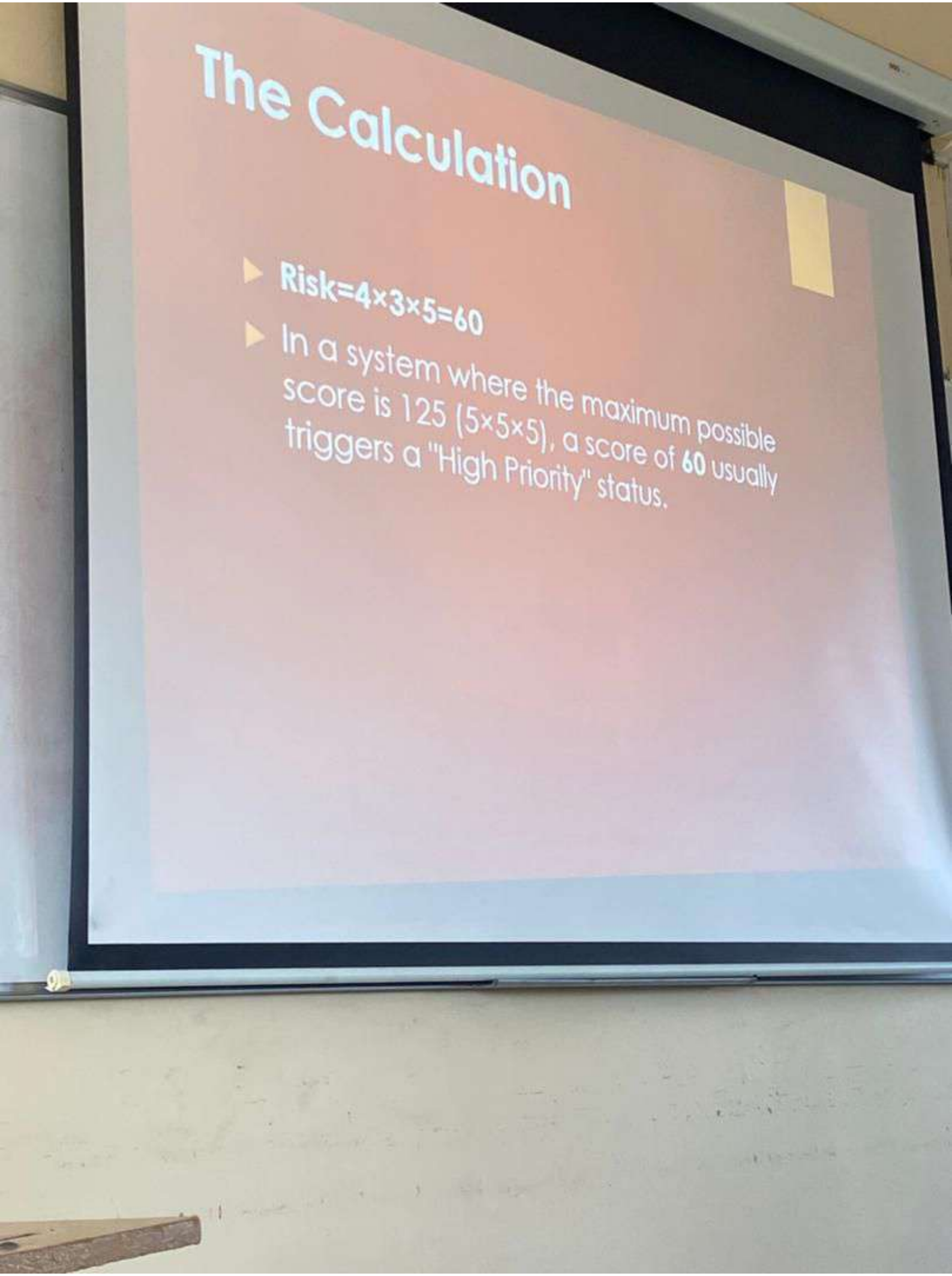
Risk Calculation

- **Risk = Threat × Vulnerability × Impact**
- In the context of Information Technology and cybersecurity auditing, this formula is the foundational equation for **Quantitative Risk Assessment**.
- It helps organizations **prioritize which security gaps** need the most immediate attention by assigning numerical or quantitative values to risk.



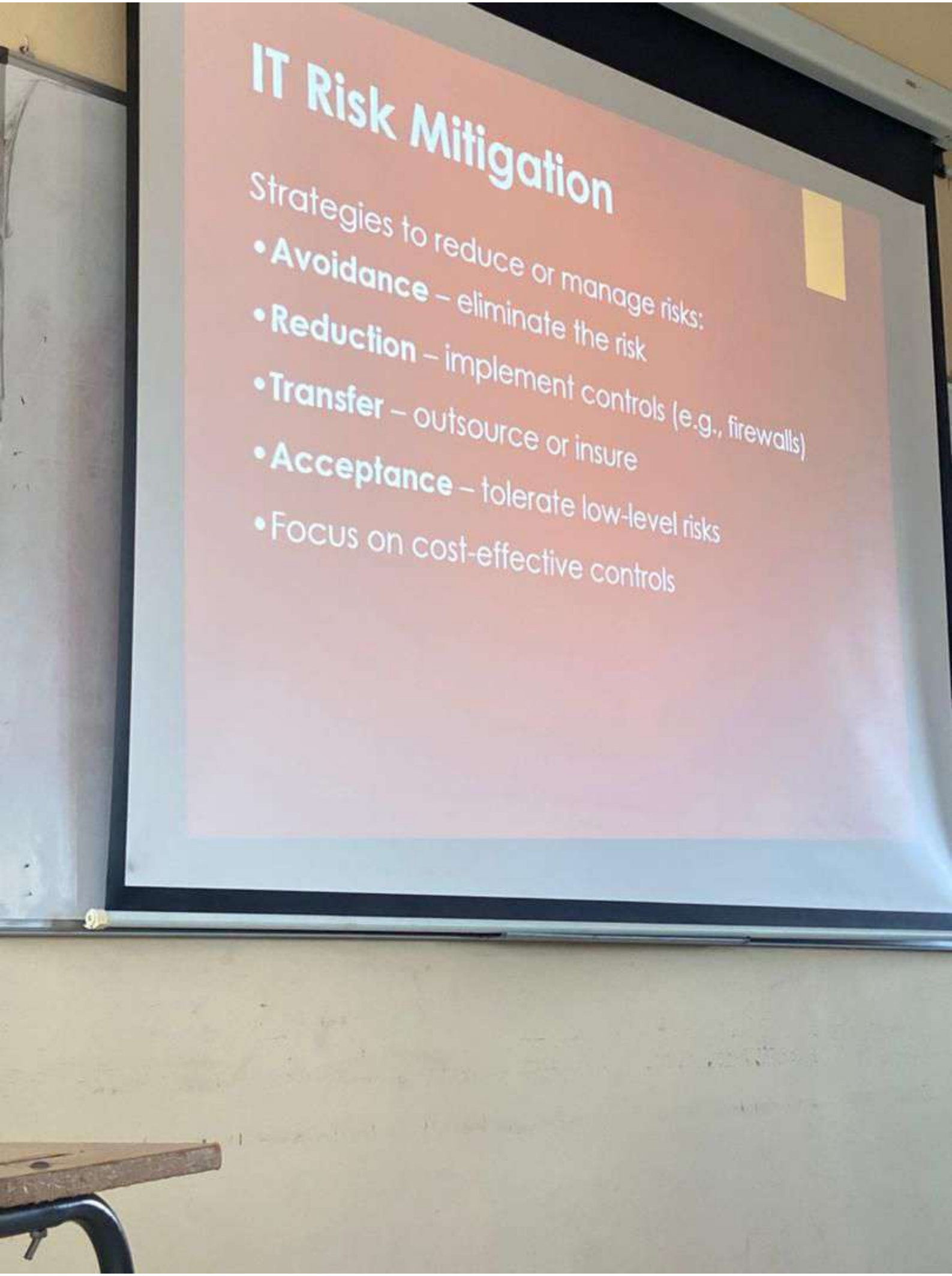
Risk Matrix

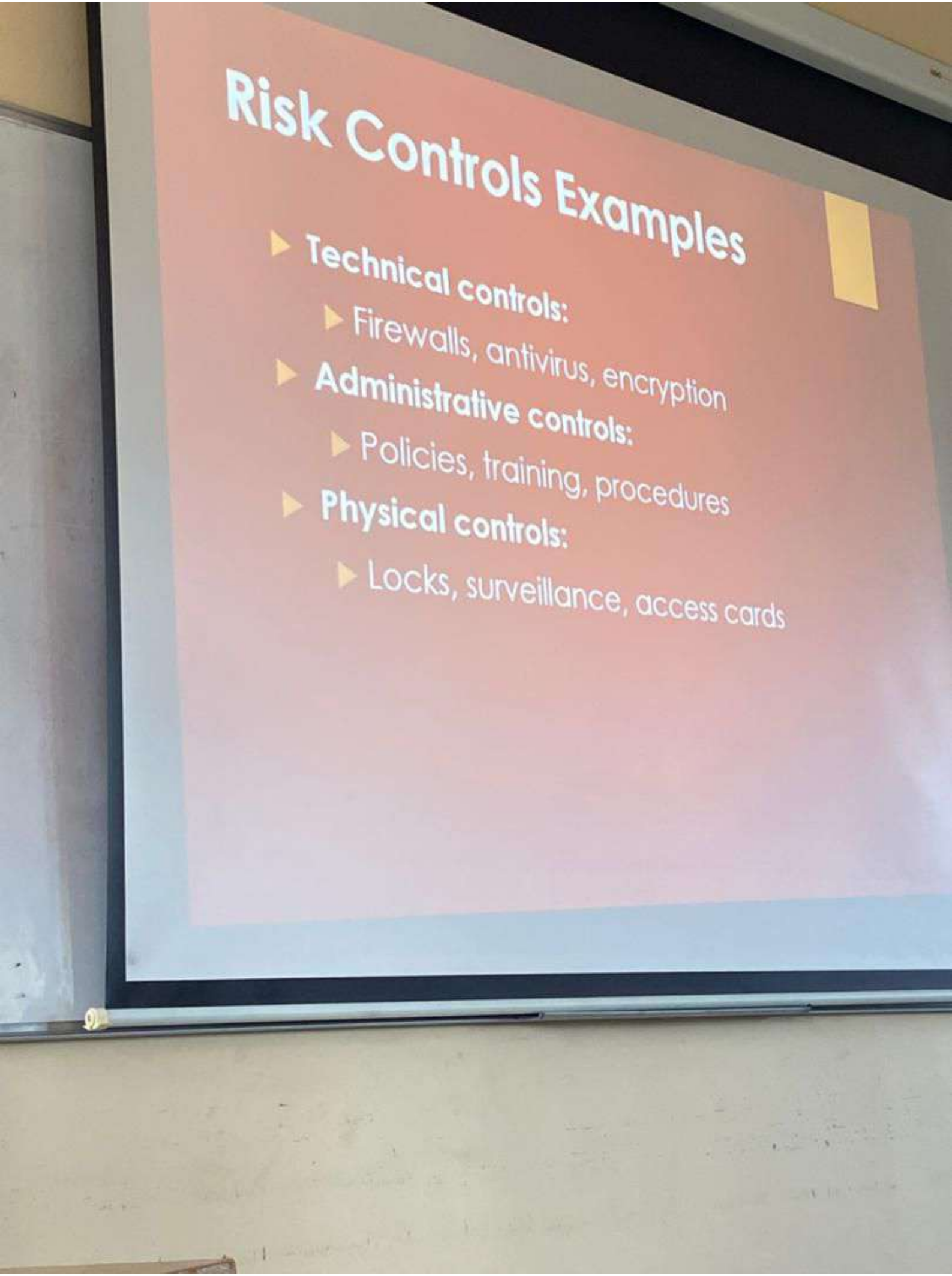
Variable	Rating (1-5)	Justification
Threat	4 (High)	Frequent phishing attempts targeting faculty and automated "bot" scans on the university network.
Vulnerability	3 (Medium)	The database has the latest patches, but some administrative staff have not completed their 2026 security awareness training.
Impact	5 (Critical)	A breach would result in a violation of data privacy laws, massive reputational damage, and potential loss of accreditation.


The Calculation
Risk=4×3×5=60
In a system where the maximum possible score is 125 (5×5×5), a score of 60 usually triggers a "High Priority" status.

Risk Matrix (Solution)

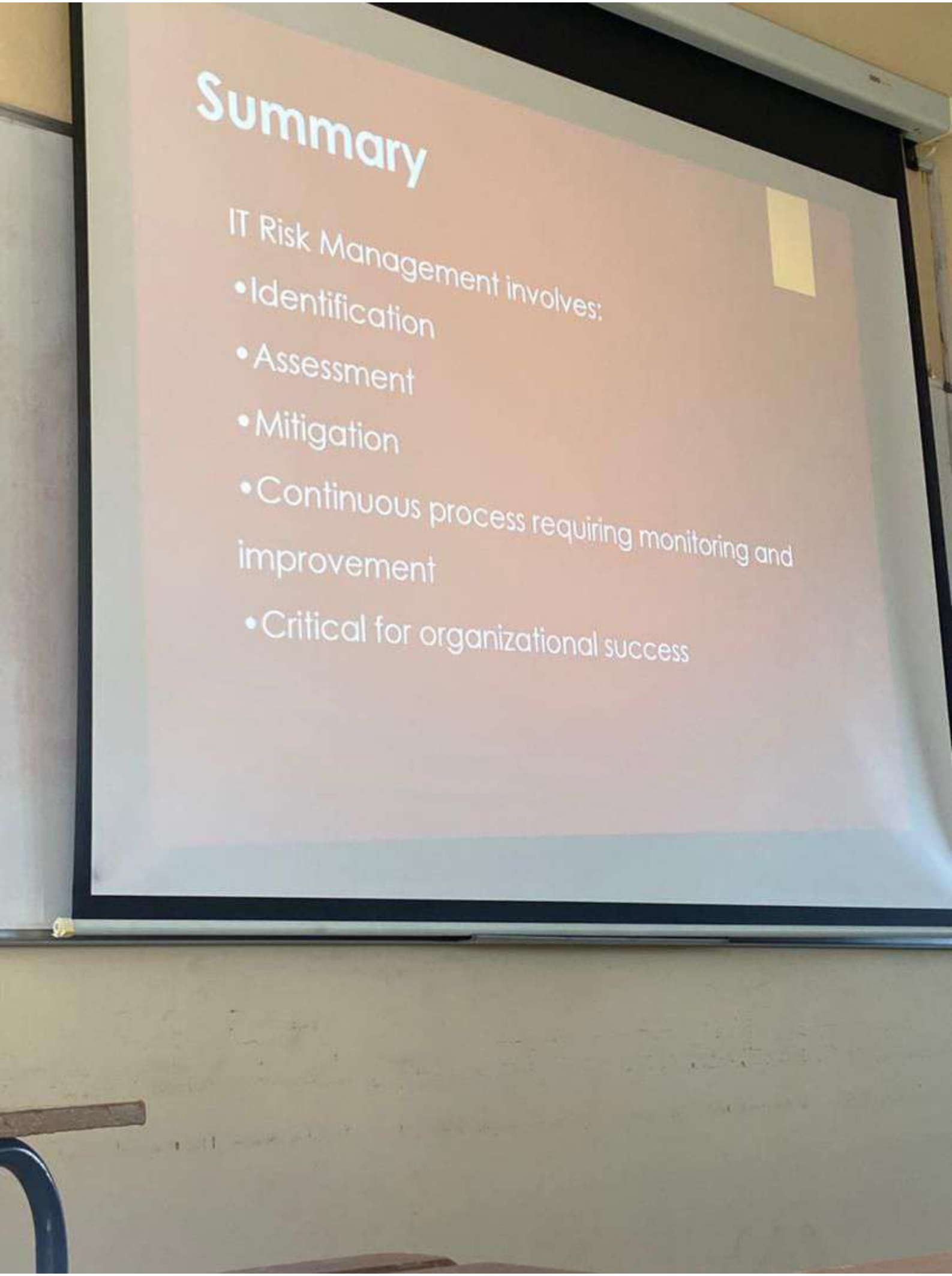
- **Visualizing the Risk Matrix**
- Auditors often plot these results on **a heatmap** to show stakeholders where the "**Red Zone**" lies.
- **Mitigation Strategies**
- Based on this formula, the university has two options to lower the score of 60:
- **To Lower Vulnerability:** Mandatory multi-factor authentication (MFA) for all staff. This might drop the Vulnerability from a **3** to a **1**, reducing the total Risk to **20**.
- **To Lower Impact:** Implement "Data Masking" so that even if a breach occurs, the actual sensitive IDs are encrypted. This might drop the Impact from a **5** to a **2**, reducing the total Risk to **24**


IT Risk Mitigation
Strategies to reduce or manage risks:
• Avoidance – eliminate the risk
• Reduction – implement controls (e.g., firewalls)
• Transfer – outsource or insure
• Acceptance – tolerate low-level risks
• Focus on cost-effective controls


Risk Controls Examples
Technical controls:
Firewalls, antivirus, encryption
Administrative controls:
Policies, training, procedures
Physical controls:
Locks, surveillance, access cards

Summary



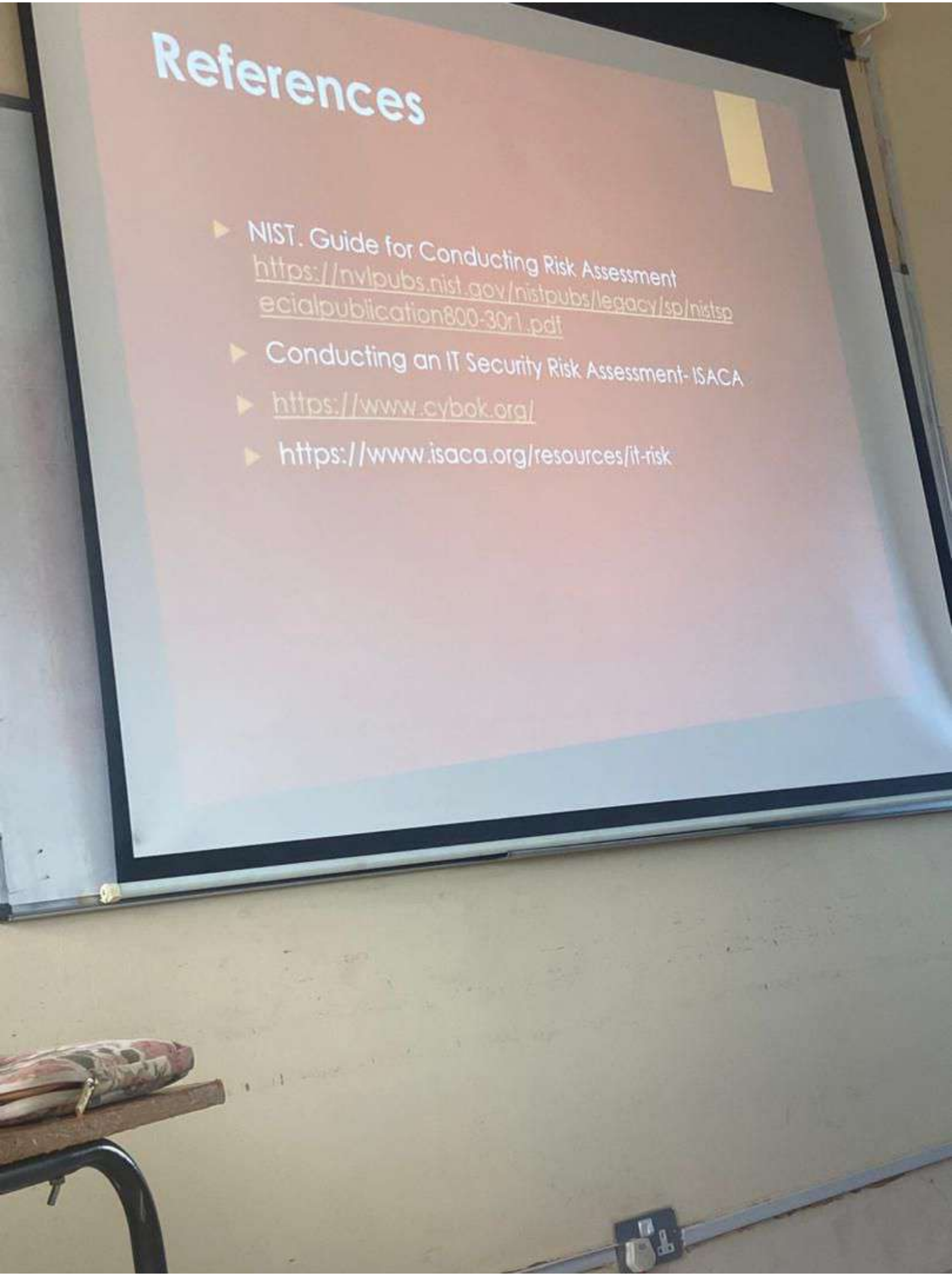

Summary
IT Risk Management involves:
•Identification
•Assessment
•Mitigation
•Continuous process requiring monitoring and improvement
•Critical for organizational success

Questions

1. Develop a risk register for a small IT organisation
2. Explain the potential risk response decisions at the **Information Systems** tier of the risk management hierarchy
3. Discuss the **non security** related risk management activities across the hierarchy that benefit from risk assessments
4. Discuss the relationship between the three-tier risk management hierarchy and the typical three level management organization

Risk Register

Risk ID	Risk Description	Threat Source	Likelihood	Impact	Risk Level	Existing Controls	Mitigation Strategy	Owner	Status
R1	Data breach due to weak passwords	Cyber attackers	High	High	Critical	Password policy	Enforce strong passwords, MFA	IT Manager	Open
R2	Malware infection								
R3	System downtime								
R4	Data loss								
R5	Unauthorized access								
R6	Network breach								
R7	Software vulnerabilities								
R8	Human error								
R9	Theft of equipment								
R10	Compliance violation								


References
NIST. Guide for Conducting Risk Assessment https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-30r1.pdf
Conducting an IT Security Risk Assessment- ISACA
https://www.cybok.org/
https://www.isaca.org/resources/it-risk